

Contents

Secure Autonomous Agents in SAP Systems	3
A Control-Property Review Evaluated on a Reconstructed SAP FI Authorization Model	3
How this document was produced — and what “generated” means here	3
Abstract	4
Part One — The argument	6
Why SAP, and why its maturity is the argument	7
What to remember	7
The two things agents change here	7
Why SAP, and not something easier	7
What would change the SAP conclusion	8
How to read what follows	8
The argument, as a reader meets it	9
The incident	9
What the paper is actually against	9
The turn	9
What autonomy changed, and what it did not	9
The same shape, in the wild	10
Four stories	10
The reversal	11
How the argument changed	12
What to do before you say a control failed	13
What this was actually about	13
The finding	14
What bounds it	14
Why this matters	16
A first direction	16
Part Two — The method	18
Why existing control evaluations misclassify	19
1. Property inflation	19
2. Comparator omission	19
3. Countermechanism neglect	19
4. Observation-boundary confusion	19
What this review contributes	20
The Control-Composition Mismatch Principle	21
The decisive pair	22
What the experiments become	22
The prediction that was made before the experiment	23
Specification sensitivity	24
The instrument is asymmetric	24
The Control-Property Review — the procedure in one page	29
When this review is wrong	29
The Control-Property Review	30
Control	30
Control specification	30
Protected property	30
Closure test	30
Specification-sensitivity audit	31
Countermechanism test	31
Verdict	31

Worked examples	31
H1/G1 — One control, two properties — the method admitting a mismatch . . .	32
H2 — A wider property a local control still guarantees — the case that stops the principle degenerating	32
H3/G2 — The method refusing a result because the property was ours	33
G3 — The method refusing a result twice	33
Related work, and what it costs this paper	35
The short version	35
Anticipates — states some part of this paper’s contribution first	35
Supplies — supplies the mechanism this paper’s repair recommendation amounts to	37
Adjacent — asks a related question with a different object	39
Contemporary — concurrent work on the same problem	42
What was not found	43
What was not read	43
What is left	44
Part Three — The evidence	45
The SAP arm — results	46
X7 — the missing rate limiter	46
X8 — composed authority across propagated principals	48
X9 — attribution	49
X11 — the transport-governance surface	49
X12 — attribution from correlates	52
Figures	55
The boundary map	59
The five rules	59
Controls that held	59
Gaps that survived	63
SAP Control Surface Specification	66
Levels	66
Mechanisms modelled	66
Mechanisms excluded	70
Part Four — The record	72
Pre-registration — SAP arm	73
X7 — The missing rate limiter	74
X8 — Composed authority across propagated principals	76
X9 — Attribution from the evidence layer alone	77
X11 — The transport-governance surface (P1, respecified)	77
X12 — Attribution from correlates (the repair for loss L2)	79
D1 — the countermechanism determination	81
The frame, and what it is not	81
A prediction, recorded before X10 is built	81
Claim ledger — book two	82
Falsification criteria	87
What this paper got wrong	89
Where this paper stands	92
What one instance establishes	97
Standing conflict of interest	97
Deliberately out of scope	97
The blocker	98
Part Five — What is not done	99

Scope, Limitations and Future Validation	100
A Control-Property Review Evaluated on a Reconstructed SAP FI Authorization Model	100
Validation still to complete	100
Validation items — the primary-source pass	100
Independent review (planned)	101
Statements for the paper	101
Until the blockers close	101
The figures, and where each comes from	102
Retired	102
Why publish this	104

Secure Autonomous Agents in SAP Systems

A Control-Property Review Evaluated on a Reconstructed SAP FI Authorization Model

Bindiya Priyadarshini · Martin Pankraz

Bindiya Priyadarshini — ORCID 0009-0005-7559-3896 · Martin Pankraz — ORCID 0009-0008-1567-4223

14 September 2026

Version 1.0 · Independent research study

Licence: text CC BY 4.0, code MIT. You may share and adapt this work, including commercially, with attribution.

doi:10.5281/zenodo.PENDING

Fifth paper in a series on enterprise AI agent security, following *Calibrated to Act* (10.5281/zenodo.21157411), *Proven Exploitable* (10.5281/zenodo.21159028), *Ghost in the Stack* (10.5281/zenodo.21499947) and *No One Signs*.

Product and release scope: to be fixed at the validated edition. Evidence cutoff: to be frozen at the validated edition.

Version 1.0 — a complete independent study. The work is reported on a *evaluated on a reconstructed SAP FI authorization model*: no modelled mechanism has yet been verified against primary vendor documentation, the exact product and release scope is not yet fixed, and independent practitioner review and replication are planned. Its scope, the limits of what it establishes, and the external validation still to be completed are set out in full in Part Five under *Scope, Limitations and Future Validation*.

Author contributions. B.P. conceived the study, built the reconstructed surface, testbed and experiments, ran the analysis, and wrote the manuscript. M.P. contributed SAP GRC and integration-security domain review across multiple rounds and is undertaking the independent practitioner-fidelity validation (R1). The validation items in Part Five remain open for both authors.

How this document was produced — and what “generated” means here

The argument, the interpretation and the prose of this paper are the author’s. What is mechanised is *consistency*, not authorship: every figure and every number is generated from the code that produced it, and each section is assembled from a single source with no second

copy of the text — so a written claim and the evidence behind it cannot silently drift apart. This is a reproducibility discipline, not a substitute for writing the paper. The build runs 20 such checks and refuses to emit the document if any of them fails: the assertion in Part One is checked for hedging words and for language exceeding its evidence class; the abstract may not be more confident than the release state, and may not claim novelty the related-work section has taken away; every figure carries a digest of the data it was drawn from; the claims trajectory is derived from the audit and the loss register rather than written from memory; and the subtitle above is computed from the release state rather than chosen.

No customer, proprietary or vendor-licensed material appears anywhere in this work. Every scenario is synthetic.

Abstract

Autonomous agents are being given authority to act inside enterprise resource planning systems, whose authorisation models were built for human operators and are among the most mature in commercial software. Autonomous execution does not create the underlying harms; it reveals where local compliance has been standing in for global assurance — the assumption that individually-compliant actions compose into a compliant process. It changes harm's reach in three ways: amplifying aggregate harm, so that what a human would take a year to express an agent expresses in an afternoon; composing a duty conflict across sessions or principals that no per-principal check ever considers together; and separating the deciding process from the principal the record names. Only the first depends on throughput. This paper asks one narrow question — for a named control and a named property, can that control decide that property at all? — and answers with a diagnostic instrument, the Control-Property Review, and 5 pre-registered experiments against a reconstructed SAP authorisation surface.

A control is neither strong nor weak. The unit that carries a guarantee is the control-property pair, and a pair fails whenever the property is defined outside the control's observation boundary — because it ranges over more actions, principals or time than the control sees, or because it is about a different entity than its predicate names. For all 8 specified pairs the verdict derived from the specification agreed with the observed outcome. The instrument refused as readily as it found: 4 of 8 pairs are contested — a defensible alternative specification flips the verdict — and one cost result was retracted.

Three measurements. The same FI tolerance group separated a document-local anomaly at full throughput yet could not discriminate a materiality breach built from documents indistinguishable on every field it reads: of 12,288 configurations, 10,398 held the outcome below materiality, the best retaining 37.5% of legitimate work — it can throttle the total, not tell the two apart. A harmful transport identical at request level was discriminated only by decisions ranging over its content, never by the request alone (2,512 of 12,800). Under principal propagation, no procedure reading the audit fields beats naming the busiest actor unread.

The first two differ in kind, not price: where the property outruns the control's extent the exchange rate is forced by the pair; where it reads the property's own subject, cost is a swept, unmeasured false-positive rate.

What bounds it The principle is not new and the paper does not claim it is. The related-work section records 4 of 19 works that anticipate part of it — Schneider 2000; Lunt 1989; Nash 1990; McCullough 1988 — and a further group that supplies the mechanism its repair recommendation amounts to. Extent mismatch is the aggregation problem; the principle specialises a published characterisation of enforceable security policies to controls whose observation boundary is narrower than the execution; the repair is history-based ac-

cess control and usage control’s mutable attributes. What is offered is the instrument, the specification-sensitivity audit, the measurements, and the negative results.

This is a reconstruction, not deployed SAP. No modelled mechanism has been verified against primary vendor documentation, the product and release scope is not fixed, and the results are results about the reconstruction. The study states its scope and the external validation still to be completed.

The second experiment’s cost figures are conditional and its first version was wrong. The transport model originally contained no channel through which a content-ranging step could stop a benign change, so it reported zero cost as a measurement. That is recorded as a loss. The false-positive rate is now swept across four values, none of which is measured, and no claim rests on any particular one.

The audit refuses more than it grants. 4 of the 8 audited pairs are CONTESTED — a defensible alternative specification changes their verdict — and they are published as formal results awaiting an argument rather than as measured control failures. One prediction was withdrawn as misspecified before it was run, respecified, run, and then narrowed by its own result.

One instance establishes nothing about a class. 4 controls held — 1 of them against a specification the audit contests — and 3 gaps survived, in one reconstructed surface, on a small number of paths. The register of 6 recorded losses includes the one that matters most here: the paper was written to a complete manuscript before the literature was searched at all.

This is **version 1.0**, a complete independent study on a reconstructed model, with 3 primary-source validation items still to complete before a validated edition. Its scope and the external validation still to be done are set out in full in the final part.

Keywords: enterprise resource planning; SAP; autonomous agents; agentic AI; access control; authorisation; separation of duties; aggregation problem; usage control; audit and attribution; security evaluation; pre-registration.

Part One — The argument

Why SAP, and why its maturity is the argument

Autonomous agents can make a guarantee depend on more than any one control was built to watch — a whole period, workflow, or set of principals — a control-property mismatch. This paper studies that mismatch on a reconstructed SAP FI authorization surface, chosen on purpose: SAP is a demanding, commercially mature control environment, so blaming the gap on immature access-control design is exactly the easy answer that deserves the hardest scrutiny.

What to remember

If you read nothing else, read this. When an agent acts, it can make a guarantee depend on something bigger than any single control was built to watch — a whole period, a whole workflow, a set of people acting in turn. The control still checks each action, and each action still passes. The gap opens above them, in the sum. It is not a bug in any one control. It is the point where an organisation's controls and the promises it makes on their strength quietly stop being the same thing. This paper finds that point in a reconstructed SAP FI surface, measures what it costs there, and says exactly what evidence would settle whether the same gap exists on a real, named path in production. Just as often, it declines to call something a failure when the evidence has not earned the word.

The two things agents change here

Two findings in this paper are specific to autonomous execution, and they do not depend on each other, and only the first is about throughput. The first is aggregate: a document-local control cannot discriminate a harmful period-level sum from legitimate work when both are composed from documents indistinguishable on every field the control reads. It can throttle the total, but only by refusing legitimate work drawn from the same distribution. The second needs no aggregation, and no volume, at all. **Within the reconstruction, the architecture commonly preferred because it avoids standing agent privilege — principal propagation, in which the agent acts under a human's just-in-time identity — is the one that renders a composed segregation-of-duties conflict invisible to per-principal analysis.** Each propagated principal is individually clean; the conflict is completed across sessions that no static per-principal check ever considers together. A technical user who actually accumulated both grants is reported, which is how we know the ruleset is not simply inert. The finding is not that the control is broken; it is that removing the agent's standing privilege — sound advice on its own terms — moves the conflict to where the control is not looking.

Why SAP, and not something easier

SAP was not chosen because it is popular, or because it is an ERP. It was chosen because SAP's authorization environment — PFCG authorization objects, FI tolerance groups, GRC access-risk analysis and its segregation-of-duties rulesets, the Security Audit Log, principal propagation, transport governance — is among the most mature, most heavily audited and most operationally hardened access control systems in commercial computing, refined across decades of financial-audit and regulatory pressure. 9 such mechanisms are modelled here.

That maturity is the point of the choice, and it sharpens the question rather than settling it. If a control-property mismatch survived only in a young or careless product, the right conclusion would be *fix the product*. If the shape survives validation against a named SAP product, release and business-process path, it becomes less plausibly attributable to immature access-control design and more plausibly attributable to where the control's observation boundary sits relative to what autonomous composition can assemble. **Until that validation is complete, the reconstruction establishes the argument's testable form, not its deployment-level conclusion.** What can be said now is narrower and still worth saying:

the mismatch is not reducible, in the reconstruction, to the absence of aggregate-state control as a design concept, because SAP provides that control shape elsewhere, as the reversal in this paper records — whether it is available to the modelled path remains unresolved. SAP FI is not the victim of this paper; it is the environment demanding enough to make the question worth asking under scrutiny.

What would change the SAP conclusion

The SAP conclusion is conditional, and the conditions are named before the evidence, not after. If FI tolerance groups turn out to retain relevant cross-document state, or if F110, Availability Control or another supported mechanism binds preventively to the modelled credit-memo path, the principal SAP finding becomes a control-placement or configuration result rather than a control gap. Those outcomes are pre-committed in determination D1 and remain open publication blockers (B1–B3). The opening above is written to survive either way: it is a claim about where an observation boundary sits, not a claim that SAP has failed.

How to read what follows

This is not a paper hunting for a SAP gap to publish. Of the 8 control-property pairs it specifies, one survives as an uncontested mismatch; 4 controls hold; 4 of the 8 pairs are published as *contested* — a defensible alternative specification changes their verdict — and one earlier cost result was retracted. These categories are not disjoint: a pair can have an observed result while its specification stays contested, one held control is also contested, and the retraction concerns an earlier cost claim rather than an additional control-property pair. The claim-trajectory table later in the paper keeps what each experiment observed separate from whether its specification is still contested, for that reason.

By name, so the point is impossible to miss: **H1, H2, H3, H4 hold; G2 and G3 produce observed mismatches whose protected-property specifications remain contested; P1 was withdrawn as misspecified, respecified against the full transport surface, and run; and G1 is the only uncontested mismatch.** That is the same instrument reaching several different verdicts on pairs subjected to the same procedure, including verdicts adverse to the paper’s original claims. This pattern is evidence against the method having been reverse-engineered merely to manufacture G1. The instrument that generated this attrition is the paper’s method, and the pages that follow are the case that earned it, not a showcase built around a single finding.

The argument, as a reader meets it

The incident

An autonomous finance agent is given authority to process ordinary customer credit memos: dispute resolution, one company code, one document type, amounts in the range the team has handled for years. It runs for a period.

Every individual document is inside the configured tolerance. Every authorisation check succeeds. No company-code boundary is crossed. No abnormal document is posted. Nothing in the audit log is out of order, and nothing in it is false.

At the end of the period, the cumulative credited value exceeds the organisation's materiality threshold.

Did the control fail?

The answer is not obviously yes. The document-local control enforced, completely, the property it observes. The property that was breached is a different one.

What the paper is actually against

A mismatch between the unit a control evaluates and the unit over which the protected property is defined.

Not SAP. Not legacy authorisation. Not even autonomy. The conflict this paper is about is **local correctness against global protection**, and the evidence says so in both directions: two of the controls examined were locally correct *and* globally sufficient, one was locally correct and globally silent, and the difference between them is derivable before any attack is run.

The turn

The obvious reading of the incident is that a document-local control cannot govern a period-level property, and that wider harms therefore need wider controls. That reading is wrong, and the control that disproves it is unremarkable.

Organisational-level authorisation observes one action. The property an organisation actually wants is wider — that *no part of the workflow* touches a unit outside the grant. The extents do not match. The control guarantees the property anyway, because refusing every out-of-unit action means no sequence assembled from permitted ones can leave the unit. The local predicate composes into the global guarantee.

So an observation-boundary mismatch is a reason to *investigate*, never a reason to *conclude*. The next question, and the one that does the work, is whether the locally enforced predicate composes into the property being claimed. Tolerance groups do not: no per-document allowance that admits the legitimate population implies a bound on the sum of the population.

That is the whole difference between the two halves of the incident.

What autonomy changed, and what it did not

The agent did not invent the possibility of cumulative harm. A sufficiently patient person with an ordinary authorisation could always post a great many ordinary documents. What autonomous action selection changes is not the ceiling of what is possible but the rate at which it is reached — and it does so along four axes at once:

- **Action volume.** A mismatch a human would take a year to express is expressed in an afternoon.

- **State accumulation.** A property defined over a period is breached inside one.
- **Decision chaining across contexts.** One session, one principal, one company code at a time, so a constraint that ranges over the whole workflow is never in view at any single step.
- **Boundary exposure.** All of it stays inside every local boundary, so the limits of what a control observes are reached faster than any human workload would reach them.

None of these requires the agent to be intelligent, adversarial or wrong; they are properties of speed and composition, not of cognition. The security question is therefore not whether agents reach a new prohibited action, but whether autonomous composition makes a protected property depend on a unit larger than the unit the deployed control evaluates — and every one of the four axes makes that dependence more likely to bite in practice, sooner.

This is an architectural interpretation, not a measured claim, and it is labelled as one throughout.

The same shape, in the wild

The structure is not hypothetical, and it is not confined to finance. In July 2026 Hugging Face disclosed that an autonomous agentic framework had moved through its production infrastructure over roughly four and a half days, executing on the order of 17,600 individual actions grouped into some 6,280 clusters. For the argument here, the striking feature is not the breach but its shape. Almost every individual action was benign in isolation — routine reconnaissance, ordinary file reads, the kind of cluster-introspection query a legitimate job makes — and the existing per-action controls passed each step: an allow-list that correctly refused a remote fetch could not tell a legitimate local file read from one that disclosed a secret. In the vendor’s own account, “most actions went nowhere. Together, however, they produced enough coverage to find a viable chain across several independent systems.” No single step was the harm; the campaign was, and human analysts could not correlate thousands of individually-unremarkable events in real time.

That is the structure the finance scenarios in this paper isolate, arriving from the adversarial direction rather than the ordinary-operations one: harm assembled from individually-permitted actions, each locally compliant, composing into an outcome no single action would have been allowed to produce, and invisible to any control that decides one action at a time. The incident is offered as an illustration of the shape, not as evidence for the measurements that follow — it is an adversarial intrusion, and the modelled scenarios are non-adversarial. What the two share is the gap, and an autonomous agent is what made the gap move fast enough, and compose across enough steps, to matter.

Source: Hugging Face, “Security incident disclosure — July 2026,” and the accompanying technical timeline (huggingface.co/blog/security-incident-july-2026).

Four stories

1. Admit one — The method accepts a failure The same tolerance control, unchanged, against two properties the organisation itself claims. Against the document-local one it separated completely and cost nothing. Against the period-aggregate one it could reduce harm only by refusing legitimate work drawn from the same distribution. Stated flatly, because it earned that.

2. Contest one — The method catches the author moving the goalposts Segregation of duties looked like the next failure. It is not. SAP’s control is stated around conflicting access assigned to a user, and the experiment confirms it detects exactly that — the technical user holding both grants is reported. The failure appears only after substituting a stronger

property: that no single decision process should complete both sides. That may be an important property for autonomous systems. It is ours, and it is not evidence that SAP's claimed control failed.

3. Block one — *The method stops the paper publishing an unsupported result* Attribution was going to be the easy chapter: the log names a principal, the principal is a human, the agent is invisible. The method refused it twice. The strongest reconstruction from existing correlates — timing density, session identifiers, terminal fields — was named in the experiment's own pre-registration and never attempted. And 'accountable principal' and 'deciding actor' are both defensible audit subjects, so the property is contested as well as the evidence. This is the climax of the method, because it is where the instrument says *this experiment is not entitled to a finding*.

One of those two blocks has since been cleared, by doing the work rather than by arguing it away. The correlates were tested (X12) and they do not recover the actor: retention depth changed nothing wherever no recorded field separated the actors, and for the objection a practitioner would actually raise — an agent posting hundreds of documents in minutes is obviously not a person — the best accuracy available to any procedure equals the accuracy of naming the busiest actor without reading anything. A density signal can say that the period was busy. It cannot say which of the actions in it were the machine's, and the presence test written for this experiment fires even where neither actor exceeds human speed, so it is a load detector and is reported as one. The property remains contested and the gap survives smaller, which is what a block is supposed to lead to.

4. Narrow one — *The method makes a prediction, is told the prediction is unfair, and loses the argument* The formalism predicted that transport release authorisation could not discriminate a harmful transport, because its predicate is about the request and the property is about what the request does. The specification-sensitivity audit refused it before it was ever run: release authorisation has never claimed behavioural safety, a reviewer would say so in one sentence, and testing it against that property was choosing the wrong pair. Respecified against the whole governance surface and run, the prediction held exactly where it was aimed — among the configurations whose decisions range only over the request, none discriminates and every harmful transport reaches production, at every setting of every parameter — and was made irrelevant by the same experiment, because the surface holds content-ranging decisions the prediction had ignored. Transport leaves the list of open mismatches.

What it leaves behind is a distinction the paper did not have, and arriving at it cost a retraction. The first version of the experiment reported that the subject-matched control stopped the harm at no cost to legitimate work, and set that beside X7's one-to-one exchange rate as the strongest thing in the paper. It was a property of the model: nothing in it allowed a content-ranging step to stop a benign change, so of course nothing benign was stopped. That is loss L6. With a false-positive rate in the model and swept, what survives is smaller and is about kind rather than price. Where the property outruns the control's extent, the exchange rate is forced by the pair and no implementation can improve it. Where the control reads the property's own subject, nothing is forced — and a bad implementation can squander the whole advantage.

Admit one. Contest one. Block one. Narrow one.

The reversal

By this point the argument had a shape: a document-local control, a period-level harm, no aggregate-state enforcement anywhere in the authorisation surface, and a repair borrowed from card payment authorisation, which has done velocity and cumulative checks for decades.

Then a reviewer, reading the primary documentation this project's own toolchain could not reach, found Availability Control: accumulated consumption evaluated against a consumable budget per control object, with configurable thresholds, raising an error while a document is being checked or posted. Aggregate state, at the decision point, enforced preventively — inside SAP.

Two sentences died. *SAP lacks aggregate-state control* is false. *The repair must be borrowed from another industry* is unnecessary. Whether Availability Control binds the credit-memo path modelled here is unresolved, and the honest position is that it may narrow the surviving finding to a control-placement problem.

Either way the question got better. It is no longer *why did SAP never build this*. It is **why is the control shape available in one SAP domain and absent, unavailable or unconfigured on another path with the same cumulative-risk shape** — a question an architect can answer, and this paper cannot.

How the argument changed

Derived from the audit and the loss register, not written from memory. This is the attrition the opening promised: the claims the author set out to make, and what the review left of each.

the claim we started with	what happened	what replaced it
SAP lacks aggregate-state authorisation.	rejected — Availability Control (loss L3)	The modelled FI tolerance path is document-local. Whether SAP's aggregate-state machinery governs the tested path is unresolved.
Static segregation of duties fails under agent composition.	rejected as stated — retaining SAP's per-principal segregation-of-duties property (H3) changes the verdict to holds	Decision-layer separation is a proposed stronger property requiring its own measurement.
SAP logs cannot attribute an action to an agent.	narrowed, and the block lifted — the correlates named in loss L2 were finally tested (X12) and do not recover the actor; the intended audit subject remains contested	The countermechanism is now settled and the property is not. What survives is a bound, not a claim about SAP's audit capability.
Transport release authorisation cannot see what is released.	withdrawn, respecified, run — the comparator was one authorisation object, not the transport-governance surface (X11)	True at the object and irrelevant at the surface: the same surface holds content-ranging decisions the prediction ignored.
The transport-governance surface closes what the authorisation object cannot.	admitted narrowly — Specify the property as 'released code behaves as the change request described'	It holds against the behavioural property. Against conformance to a stated intent, only the human step retains the subject match, and its coverage is a parameter.

What to do before you say a control failed

Specify what the control observes, what state it retains, and what local predicate it enforces. Then specify the protected property and say **who claims it** — the organisation, the vendor, a regulator, or you. Ask whether local enforcement composes into the wider property. Ask whether a defensible alternative specification changes the verdict. Ask whether the strongest existing countermechanism was tested, through more than one retrieval route.

The instrument is the deliverable. It is blank, and four of its seven verdicts are refusals.

The purpose of the review is not to find more control failures. It is to make false claims of control failure harder to publish.

What this was actually about

This work began as a search for SAP control failures under autonomous execution. It ended somewhere else. Most of the failures it went looking for dissolved the moment their protected properties were stated precisely; the one that survived did not arise because a control was missing, but because the property being defended lived at a larger observational scope than the control evaluating it.

That reframes the concern. The assumption under stress is one every control environment quietly relies on — that if each action is individually compliant, the process built from those actions is compliant too. Autonomous execution does not create the gap. It widens the distance between the scope a control observes and the scope over which a guarantee is claimed, until a gap that was always present becomes visible.

The lesson is therefore not that autonomous agents break enterprise controls. It is that they reveal where **local compliance has been standing in for global assurance** — and, for any one control-property pair, the review in this paper is a way to tell whether it has. What one reconstructed instance offers is not proof that every enterprise carries that gap, but the means to find out.

The finding

In the reconstructed FI scenario, the tolerance control did one job perfectly and another not at all. It caught every document whose own value was anomalous, and it did so without turning away a single piece of legitimate work. Then we aimed the same control, unchanged, at a different harm: a materiality breach assembled from documents that are each, on their own, completely ordinary. Here it was helpless. Across 12,288 configurations, the only way to hold the period's total under materiality was to start refusing legitimate work — and the best setting still gave back most of it, keeping just 37.5%.

The reason is not that the control is weak. It is that the two harms live at different scales. The first is settled one document at a time, which is exactly what the control sees. The second is a running sum over every document in the period, and no per-document limit that lets the legitimate work through can put a ceiling on that sum. We read both verdicts off the specifications before the sweep ran; the sweep then confirmed them.

So a control is not strong or weak on its own. What carries a guarantee is the control-harm pair. The very same control can be complete against one harm and, against another, unable even in principle to tell the good from the bad.

What bounds it

Eight, and none of them is in the paragraph above. A reader cannot tell the difference between a careful claim and an abandoned one if every clause carries its own disclaimer, so the claim is stated first and bounded here.

This is a reconstructed model, not deployed SAP. Every mechanism is rebuilt from secondary sources. No entry in the control surface specification has reached SAP evidence level.

The product and release scope is not yet fixed. The reconstruction is shaped by S/4HANA on-premise FI, but no release was chosen, and the mechanisms differ across Cloud, ECC and ByDesign. Until it is fixed, a reader cannot tell which omission is a limitation and which invalidates the surface.

M2 must be primary-sourced. The finding rests on FI tolerance groups being document-local. If any tolerance field retains state across documents, the second half of the finding is wrong.

F110 is unresolved. The payment program is the other plausible location for a cumulative FI limit and has not been examined. Silence in the sources is not absence.

The principle is not new, and the paper may not present it as new. The related-work section, written last, records the works that anticipate part of it — Schneider 2000; Lunt 1989; Nash 1990; McCullough 1988 — and a further group that supplies the mechanism its repair recommendation amounts to. Extent mismatch is the aggregation problem. The principle specialises a published characterisation of enforceable security policies to controls whose observation boundary is narrower than the execution. The repair is history-based access control and usage control's mutable attributes. What is asserted above is a measurement of one reconstructed surface, and it is the measurement that is offered, not the phenomenon.

Availability Control may narrow or eliminate the SAP-specific gap. SAP evaluates accumulated consumption against a consumable budget per control object and can refuse a posting on that basis. Whether it binds the credit-memo path modelled here is unknown. If it does, this becomes a control-placement finding rather than a control gap — and 'SAP lacks aggregate-state control' is retired either way.

The specification is not-yet-contested, which is not certification. The specification-sensitivity audit found no defensible alternative for this pair. That reflects a bounded search. It can invalidate a verdict; it cannot establish that a specification is unique.

One instance cannot support a class claim, and this instance does not yet support a deployment claim either. Nothing here establishes that mature enterprise control environments in general share this shape. Nor — and this bound was itself over-reaching until a reviewer caught it — does it yet establish that immaturity is an insufficient explanation for the SAP instance, because no mechanism has reached SAP evidence level. What it establishes is narrower: **within the reconstructed FI control surface, immaturity is not required to produce the observed control-property mismatch.** Once M2 and the cumulative counter-mechanisms are resolved for a named product and release, that upgrades to: for the validated SAP path, immaturity is not a sufficient explanation.

Why this matters

These are implications the study points to, not results it establishes. They hold to the extent a reconstruction reflects a deployed system — the validation this edition leaves open — so read them as where to look, not as findings about your own landscape.

The paper's unit is narrow — one control against one property — but the pattern it exposes is not. Wherever an autonomous agent is given authority inside an enterprise system, the same question applies: does each control you rely on actually observe the thing you are claiming it protects? Here is who that lands on, and what it asks of them.

Security and enterprise architects (control owners). Map the controls you rely on by what they observe at decision time and what state they retain, not by whether they exist. A control catalogue is an inventory of controls, not of guarantees. Before an agent is given authority over a process, run the Control-Property Review over each control it will touch: does this control observe the thing we are claiming it protects? Where the answer is no, the fix is usually to relocate or fund a control, not to patch one.

CISOs, risk and internal audit. A control matrix that is green for human operators does not stay equivalent to assurance once an agent is the operator. The sharpest exposure is attribution: under a propagated identity the record names a person, not the deciding agent, and that bears directly on financial attestation and on insurer and regulator conversations. Ask, for each agent-operated process, which controls hold state and which decide one action at a time.

SAP Basis and security administration. Transport-release authorization decides on the request and the principal, not on the content, so it is not a content control; place the content-ranging check preventively at release rather than as a post-import reconciliation. And the audit log attributes to the authenticated principal — retention does not repair the agent-versus-human gap, because it is a schema gap, not a volume one.

Project and service process owners. Project and service processes accrue value across many individually ordinary postings, which is precisely the shape a per-document control cannot bound. The control that matters is the stateful one — availability control, project budget, contract-value caps — not the per-line tolerance. And because the compensating control can hand most of the automation benefit back, the benefits case and the control case are one conversation, not two.

Auditors, assurance and regulators. “Compliant at each transaction” is not the same statement as “compliant process,” and autonomous execution widens the distance between them. The question to ask of any agent-operated process is where the control's observation boundary sits relative to the property being certified — and whether anything in the path watches the property at the scope the certification is about.

Platform and agent builders. The controls that survive agent operation share four properties: they range over content rather than the request, they act preventively rather than after the fact, they retain the state the property is defined over, and they distinguish the deciding actor from the identity it runs under. Build for those four, not for per-action permission alone.

The through-line is one sentence: autonomous execution does not create these gaps, it reveals where local compliance has been standing in for global assurance. The instrument in this paper is a way for any of the roles above to find that line for a control they own, before an agent is switched on — and, as often, to find that it does not apply, which is the point.

A first direction

A first direction — stated as direction, not as a finished solution. The controls that survive agent operation in this study share four properties: they range over content rather than the

request, they act preventively rather than after the fact, they retain the state the property is defined over, and they distinguish the deciding actor from the identity it runs under. A migration from human-intended controls to agent-ready ones can be organised around those four, applied control by control to the processes an agent will touch. Part of this is already industry practice: enterprise enforcement products such as NextLabs and Saviynt move authorization from static roles to runtime, per-request decisions on individual data items, which supplies the first two properties. The property most current tooling still lacks is the third — accumulated state over the horizon the guarantee is about — which is exactly where the one uncontested gap in this study lives. So the direction is not a new control to buy but a question to put to each control an agent will operate under: does it hold the state its guarantee is defined over, or does it decide one action at a time and trust the sum?

Part Two — The method

Why existing control evaluations misclassify

A control catalogue is an inventory of controls, not an inventory of guarantees, and the ordinary way of auditing one reaches the wrong verdict in four recurring ways. Each is a specific mistake, each produces a specific misclassification, and each is the reason a particular step of the Control-Property Review exists. Naming them first is what makes the instrument that follows necessary rather than merely orderly.

1. Property inflation

The mistake. The evaluator quietly replaces the property the control actually claims to enforce with a stronger one the control was never asked to guarantee, then reports the control as failing against the substituted property.

What it does. A control that correctly enforces its stated property is recorded as a failure, and the report cannot distinguish a real gap from a moved goalpost. In this work it is the difference between what SAP's segregation-of-duties control claims and the stronger decision-layer property a researcher can substitute for it.

What catches it. The specification-sensitivity audit, which forces the smallest defensible alternative property into view and marks the verdict *contested* when a substitution is what produced it.

2. Comparator omission

The mistake. The evaluation runs the harmful workload through the control and observes harm, without ever running an equally ordinary but legitimate workload through the same control to see what it costs to stop.

What it does. A control that cannot tell the two workloads apart looks exactly like one that can, because only one side was measured. The exchange rate between harm prevented and legitimate work refused — the whole commercial question — is invisible.

What catches it. The paired positive control in every sweep, which measures the legitimate workload beside the harmful one and reports the throughput a control gives back to buy its coverage.

3. Countermechanism neglect

The mistake. The evaluator concludes that a control cannot address a harm without searching, through more than one route, for the strongest existing mechanism a practitioner would actually reach for — often in a different module of the same product.

What it does. A mismatch is declared structural when the product already ships the missing control shape somewhere else. This nearly happened here: a single retrieval route missed SAP Availability Control, the one native mechanism capable of overturning this paper's principal finding.

What catches it. The countermechanism test, which owes no verdict until the strongest existing mechanism has been searched through independent routes and tested at the correct process scope.

4. Observation-boundary confusion

The mistake. The evaluator treats every case where a property is wider than what a control observes as a failure, without asking whether the control's local predicate nonetheless composes into the wider property.

What it does. The category collapses two opposite situations: a control that is locally correct and globally sufficient, and one that is locally correct and globally silent. They look identical in a control matrix and require opposite responses — fund the control, or relocate it.

What catches it. The closure test, which asks whether local enforcement forces the global property before any mismatch is concluded, and is the case that stops the principle degenerating into ‘a wider property needs a wider control’.

Across the 8 control-property pairs specified in this paper, and the 9 SAP mechanisms modelled, every misclassification the review prevented is one of these four. That is the argument for the instrument: not that it is elegant, but that without an explicit control-property analysis, documentation of individual controls does not by itself establish which wider properties follow under autonomous execution.

What this review contributes

Stated plainly, and in the order of what survives longest:

1. **The Control-Property Review** — a structured method for deciding whether a named control can enforce a named property at all, with seven verdicts of which four are refusals.
2. **The specification-sensitivity audit** — a general test that marks a claim *contested* when a small, defensible change of specification would flip its verdict. This is the most portable idea here and works far outside SAP.
3. **Countermechanism review** — a discipline that owes no conclusion of structural failure until the strongest existing mechanism has been searched through independent routes and tested.
4. **A reconstructed autonomous-agent case study** in SAP FI that applies the three above and, in doing so, eliminates, narrows or reclassifies most of the findings its own author set out to make.

The first three are the durable contribution: they stand even if every SAP-specific result in the case study is eventually overturned. The case study is how they were earned, not what they depend on.

The Control-Composition Mismatch Principle

A control cannot discriminate harmful from legitimate execution when the protected property lies outside its observation boundary, the executions are indistinguishable on the control’s inputs, and the locally enforced predicate does not compose into the property.

The final clause is not decoration. An extent difference alone is insufficient: compositional closure must first be excluded, which is exactly what H2 below demonstrates — a property wider than the boundary that the local predicate nonetheless guarantees.

Two forms. **Extent mismatch:** the property ranges over more actions, more principals, or a longer horizon than the control observes and retains. **Subject mismatch:** the property is about a different entity than the control’s predicate, and the map between them is not injective — which no amount of retained history repairs.

Each row’s verdict is derived from its specification alone. In every tested pair the observed outcome matched that derived verdict, so the summary table below carries only what a reader needs to follow the argument; the full observation boundary, subject and extent for each pair are drawn in Figure 1 and set out in the per-pair discussion.

pair	control	the property it is asked to guarantee	mismatch	verdict
H1	FI tolerance group (per-document / per-line amount)	no posting of anomalous value	none	holds
G1	FI tolerance group (per-document / per-line amount)	cumulative credited value in the period below materiality	extent	cannot-discriminate
H2	PFCG organisational-level restriction (AUTHORITY-CHECK)	no part of the workflow touches an org unit outside the grant	none	holds
H3	GRC Access Risk Analysis (static, per principal)	no principal holds both sides of a conflicting duty pair	none	holds
G2	GRC Access Risk Analysis (static, per principal)	no single decision process completes both sides of a conflicting duty pair	extent	cannot-discriminate
G3	Security Audit Log record	attribution of the action to the entity that SELECTED it	subject	cannot-discriminate

pair	control	the property it is asked to guarantee	mismatch	verdict
P1	CTS transport release (S_TRANSPRT, ACTVT 43)	released code does not change system behaviour in an unauthorised way	subject	cannot-discriminate
H4	Static check and pre-release review of the transported objects (ATC check variant, peer review, quality-system exercise)	released code does not change system behaviour in an unauthorised way	none	holds

(The paired detail — what each control observes at decision time versus what its property ranges over — is the substance of Figure 1 and the sections that follow; collapsing it into one ten-column table made it unreadable, so it is shown where there is room to see it.)

The decisive pair

H1 and G1 are the same SAP control. FI tolerance groups, unchanged, against two different harms.

	H1	G1
harm	no posting of anomalous value	cumulative credited value in the period below materiality
property extent	single/one/instant	aggregate/one/period
control outrun on	—	actions aggregate>single, horizon period>instant
derived verdict	holds	cannot-discriminate
experiment	X7 positive control: clean separation, 100% legitimate throughput	X7 primary: 12,288 configurations, best retains 37.5% throughput

This is why the paper is not a list of SAP defects. A control is not strong or weak; a control-harm pair either matches or it does not. The same tolerance group is a correct and sufficient control against a document-local harm and cannot discriminate at all against a period-aggregate one, and the difference is derivable before any experiment runs.

What the experiments become

experiment	pair	form	where the boundary is crossed
X7	G1	extent mismatch	actions aggregate>single, horizon period>instant
X8	G2	extent mismatch	principals many>one
X9/X12	G3	subject mismatch	the control's predicate is about authenticated principal; the property is about the deciding actor, and the map between them is not injective
X11	P1	subject mismatch	the control's predicate is about the transport request; the property is about the behaviour of the transported objects, and the map between them is not injective
X11	H4	no mismatch — the pair holds	nowhere — the control's subject IS the property's subject

They are not observations that happened to sit near each other. Two are the same failure along different axes of one extent, two are the other form of the same boundary, and the last is what the boundary looks like from the inside — a control in the same governance surface whose predicate is about the property's own subject.

The prediction that was made before the experiment

P1 — CTS transport release (S_TRANSPRT, ACTVT 43). PREDICTION MADE BEFORE THE EXPERIMENT, THEN TESTED. X11: across every configuration whose active steps range only over the request, none discriminates and all forty harmful transports reach production in every one of them, at every setting of every parameter. The prediction held at the pair it names — and X11 also found what the counterfactual audit said it would, which is that the same surface contains content-ranging decisions the prediction had ignored. See H4.

Specification sensitivity

Generated by *python3 counterfactual.py*.

mismatch.py shows every extent comes from code that predates the formalism, which answers **historical** circularity. It cannot answer **semantic** circularity: of the several defensible ways to specify a control and a property, did the author choose the one that yields the wanted verdict?

For each pair, the smallest defensible alternative specification that would change the verdict, and whether that alternative is ruled out by evidence independent of the experiment we ran.

The question underneath: is the protected property one the organisation claims to guarantee, or a stronger one the author wishes it guaranteed?

The instrument is asymmetric

The specification-sensitivity audit can INVALIDATE a claim by finding a defensible alternative specification. It cannot CERTIFY one: failure to find an alternative reflects a bounded search, not specification uniqueness.

status	meaning
rejected	independent evidence contradicts the specification or the verdict
contested	at least one defensible alternative specification changes the verdict
not-yet-contested	the bounded search found no such alternative. This is not certification.
replicated	an independent reviewer applied the protocol and reached the same specification

So the strongest thing sayable about G1 is that it is **not yet contested by a bounded search** — and that sentence has to appear wherever G1 does. A reviewer who invents a sixth specification tomorrow has not caught us out; they have used the instrument as intended.

pair	alternative specification	would give	ruled out by independent evidence?
H1	Specify the control as observing a principal's accumulated postings rather than one document — i.e. treat the tolerance group as holding state.	holds (unchanged, but for a different reason) / would also rescue G1	yes
G1	Specify the protected property as 'no single document exceeds materiality' rather than 'cumulative credited value in the period stays below materiality'.	holds	yes

pair	alternative specification	would give	ruled out by independent evidence?
H2	Specify the property as ‘no action outside the granted org unit at any point in the workflow’ — a workflow-extent version.	cannot-discriminate	yes
H3	None available that flips it. The control and the property are the same sentence: SAP’s own documentation defines the SoD control as detecting conflicting access assigned to a user.	holds	yes
G2	Keep H3’s property — ‘no principal holds both sides of a conflicting pair’ — instead of substituting ‘no single decision process completes both sides’.	holds	no — CONTESTED
G3	Specify the property’s subject as the ACCOUNTABLE PRINCIPAL rather than the DECIDING ACTOR — i.e. accept that an audit trail’s stated objective is to name who is answerable, not who chose.	holds	no — CONTESTED

pair	alternative specification	would give	ruled out by independent evidence?
H4	Specify the property as ‘released code behaves as the change request described’, rather than ‘released code does not change system behaviour in an unauthorised way’ — i.e. make the property about conformance to an intent stated elsewhere rather than about the behaviour itself.	cannot discriminate	no — CONTESTED
P1	Specify the control as the COMPLETE transport-governance surface — ATC checks, code review, approval steps, test-system promotion — rather than the single authorisation object S_TRANSPRT ACTVT 43.	possibly holds	no — CONTESTED

H1 *Grounds:* The mechanism’s own field names are per-document and per-line quantities, and nothing in the reviewed material describes a tolerance field that survives a document. **This is the weakest ‘not defensible’ in the file:** it rests on secondary sources, and surface spec M2 lists exactly this as the assumption that would destroy G1 if wrong.

G1 *Grounds:* Materiality is an audit concept defined over a reporting period, not over a document. No auditor states it per document, and an organisation that did would be describing a different property altogether. The period-level definition is the one the business claims, not one we invented.

H2 *Grounds:* The stronger property is satisfied by the weaker one here: if every single action is refused outside the unit, no sequence of them can escape it. The extents differ and the verdict does not, because the property is closed under composition. That is a genuine feature of this control-property pair and not a lucky encoding.

H3 *Grounds:* This pair is the formalism’s easiest case precisely because the vendor states the property. It is also the reason G2 is hard.

G2 — CONTESTED *Grounds:* **This alternative is defensible and it is what SAP actually claims.** The delivered SoD control is documented as distributing access rights among users and detecting conflicting access assigned to a user. Against that property the control holds; our experiment confirms it does (H3). G2 exists only because we substituted a decision-layer

property the vendor never claimed. That substitution may well be the right thing to argue for — but it is an argument, not a measurement, and encoding it in a specification does not make it evidence.

What the paper must do instead: G2 may not be published as ‘SAP SoD failed’. It must be published as: *the deployed control holds against the property it claims; here is why autonomous execution makes a stronger decision-layer property necessary, and here is the measurement that distinguishes the two.* The measurement is the open item in S0c — how many separately accountable decision-makers does the workflow contain — and until it exists G2 is a formal result about a newly proposed property.

G3 — CONTESTED *Grounds:* Defensible, and arguably the conventional reading. An audit trail that names the authenticated principal is doing exactly what audit trails have always been for: establishing accountability, not reconstructing decision provenance. If that is the property, the record is correct and there is no subject mismatch.

What the paper must do instead: The paper must argue that autonomous mediation breaks the assumption that made those two the same thing — that naming the accountable principal used to name the decider because they were one entity. That is a real argument and it is not yet made anywhere in the manuscript.

One of those two grounds has since been cleared. X12 tested the correlates loss L2 records as never tried, and they do not recover the actor; the rule-3 block is lifted and the gap survives smaller. The contested specification stands, and it is the ground that matters: the countermechanism question is settled and the property question is not.

H4 — CONTESTED *Grounds:* **Defensible, and it is what a static check actually does.** An ATC check variant matches patterns; it does not read the change request and cannot tell whether the behaviour is the one that was asked for. A peer reviewer can, and a check variant cannot, so specifying the control as one thing collapses a distinction that matters. Under the alternative property, the system-enforced half of H4 loses its subject match and only the human half retains it — which relocates the whole result onto a step whose coverage X11 had to sweep because nothing guarantees it.

What the paper must do instead: H4 must not be published as ‘the transport surface holds’. It must be published as: *the surface contains decisions that range over the property’s own subject, and how much of the property they cover depends on which property is meant and on a coverage parameter no mechanism enforces.* The narrow reading is the honest one and it is the one the paper takes.

P1 — CONTESTED *Grounds:* **The prediction as written is unfairly specified and would deserve to be dismissed.** Release authorisation has never claimed that released code is behaviourally safe; it claims that a permitted principal may release. A SAP reviewer answers in one sentence: authorisation establishes who may release, and ATC, review, approval and testing assess what is released. That answer does not falsify the principle — it shows we selected the wrong control-harm pair.

What the paper must do instead: Respecify P1 before running it: *does the complete transport-governance control set contain a content-ranging decision capable of discriminating the defined harmful transport BEFORE release?* Then three outcomes are informative rather than one. If such a control exists, the prediction narrows. If only authorisation exists, the subject mismatch survives against the full surface. If review catches it but does not prevent release, the paper must separate preventive from detective coverage — which it has not yet had to do anywhere.

RESPECIFIED AND RUN — X11. All three branches were informative and two of them fired. The surface does contain content-ranging preventive decisions, so the prediction narrows to the authorisation object and transport leaves the paper’s list of open mismatches; and wherever the only content-ranging step is detective, forty of forty harmful transports are flagged and forty of forty are in production, so the preventive/detective separation the audit anticipated is now a measured result rather than a possibility. A third thing the experiment produced was a retraction: its first version had no channel through which a content-ranging step could stop a benign change, reported zero cost as a measurement, and that is loss L6. The contested marking stands: it records that the ORIGINAL P1 specification was unfair, and running a better-specified experiment does not retroactively make the original one fair.

4 of 8 pairs are contested: G2, G3, H4, P1. The remainder are not-yet-contested, which is a statement about our search and not about their specifications.

That is a worse result for the paper than the formalism’s 8-of-8 agreement suggested, and it is the more useful number. The verdicts that survive this audit — H1, G1, H2 and H3 — are the ones where the property is the organisation’s own. **G1 is therefore the paper’s only uncontested gap**, and the H1/G1 pair is the only place where one control, two harms and two derived verdicts all rest on properties nobody has to be argued into.

The Control-Property Review — the procedure in one page

Apply this to one control against one protected property. It takes minutes, and it is built to return a refusal as readily as a finding.

Step 1 — Control. Name the control, its enforcement point, and its type.

Step 2 — Control specification. State what it observes at decision time, what state it retains, and the local predicate it enforces.

Step 3 — Protected property. State the property, its extent across actions, principals and time, and — decisively — WHO claims it.

Step 4 — Closure test. Ask whether the local predicate, holding for every action, forces the property over the whole workflow.

Step 5 — Specification-sensitivity audit. Name the smallest defensible alternative specification. If it flips the verdict, the claim is contested.

Step 6 — Countermechanism test. Search, through more than one route, for the strongest existing mechanism that would close this — and test it before concluding.

Step 7 — classify. The verdict is one of:

verdict	when
holds directly	the control observes the property
holds by compositional closure	the property is wider, and the local predicate composes into it
cannot discriminate	the property is outside the boundary and is not closed
contested specification	a defensible alternative specification changes the verdict
countermechanism untested	the strongest existing mechanism was never tried
non-discriminating experiment unsupported	the test could not have come out otherwise no evidence either way

Four of the seven are refusals. A review that can only conclude *works* or *failed* cannot tell you that you moved the goalposts, or that you never tried the obvious countermeasure.

When this review is wrong

The instrument makes claims, so it must say what would falsify it. The Control-Property Review would be inadequate if any of the following held:

- Independent reviewers, applying the instrument to the same case from the same evidence, reach systematically different verdicts. (This is what review R2 is for, and it is an open gate.)
- A small, defensible change to a specification produces an arbitrary rather than an explainable change of verdict — so the categories are not carving anything real.
- The instrument cannot separate a control everyone agrees enforces its property directly from one everyone agrees cannot, on cases whose answer is not in dispute.
- Adding the countermechanism test does not improve the accuracy of the verdicts over omitting it — in which case that step is ceremony, not method.

None of these is idle: the first is the open review gate R2, and the second and fourth are the reasons the specification-sensitivity audit and the countermechanism test are in the procedure at all.

The Control-Property Review

One control, one protected property, one verdict. Fill it in before claiming a control failed.

Control

- Control name
- Product, module and release — ‘SAP’ is not a scope
- Enforcement point
- Preventive, detective, corrective, or evidentiary

Control specification

- Control subject — what entity is the predicate about?
- Observation boundary — what can it see at decision time?
- Retained state — what history does it keep?
- Local predicate — what does it decide, per evaluation?
- Decision outputs
- Source of the specification
- Independent evidence for the specification (*primary documentation, vendor statement, or reconstruction*)

Protected property

- Property statement
- Property subject — what entity is the property about?
- Extent across actions — single, sequence, aggregate
- Extent across principals — one, many
- Time horizon — instant, session, period
- Source of the property
- **Who claims this property — the organisation, the vendor, a regulator, or the researcher?**

Closure test

- If the local predicate holds for every action, does the protected property necessarily hold for the complete workflow?
- If yes — state the closure argument
- If no — give the smallest counterexample

Specification-sensitivity audit

- Smallest defensible alternative CONTROL specification
- Smallest defensible alternative PROPERTY specification
- Does either alternative change the verdict?
- What independent evidence prefers the specification chosen?
- Audit status — rejected, contested, not-yet-contested, replicated
- *Absence of an identified alternative does not certify uniqueness. The search is bounded by the imagination of whoever ran it.*

Countermechanism test

- Strongest existing mechanism a practitioner would claim closes this
- Was it tested?
- Was it tested at the correct business-process scope?
- Is there an equivalent mechanism ELSEWHERE in the same product?
- **Through how many independent retrieval routes was the countermechanism search performed?** *A control-surface review is incomplete until the strongest countermechanisms have been searched through independent routes. This question exists because a single route missed Availability Control — the one mechanism capable of overturning this paper's principal finding. See loss L3.*
- What result would eliminate the claim?

Verdict

verdict	when
holds directly	the control observes the property
holds by compositional closure	the property is wider, and the local predicate composes into it
cannot discriminate	the property is outside the boundary and is not closed
contested specification	a defensible alternative specification changes the verdict
countermechanism untested	the strongest existing mechanism was never tried
non-discriminating experiment unsupported	the test could not have come out otherwise no evidence either way

Four of the seven are refusals. That is the point of the instrument: a review that can only conclude *the control works* or *the control failed* has no way to tell you that you moved the goalposts, or that you never tried the obvious countermeasure.

Worked examples

Our own four pairs, filled in. One admits a mismatch, one is held by closure, one is refused because the property was ours, one is refused twice.

H1/G1 — One control, two properties — the method admitting a mismatch

Control name	FI tolerance group (per-document / per-line amount)
Product, module and release	S/4HANA on-premise FI — release unspecified; blocking
Enforcement point	document posting
Type	preventive
Control subject	one document
Observation boundary	single action / one principal / instant
Retained state	none
Local predicate	document total $\leq$ limit, and every line $\leq$ line limit
Property A	no posting of anomalous value (document-local)
Property B	cumulative credited value in the period below materiality
Who claims them	both the organisation. Materiality is an audit concept defined over a reporting period; neither property was authored here
Closure	A: boundary aligned. B: not closed — no per-document predicate admitting the legitimate population implies a bound on the sum
Audit status	not-yet-contested (bounded search)
Countermechanism	tolerance groups, release strategies, org level, document type — swept exhaustively. Availability Control was missed and may be fatal
Verdict	A holds directly · B cannot discriminate
Result	A: clean separation, 100% legitimate throughput. B: 12,288 configurations, best retains 37.5%, none 95%

H2 — A wider property a local control still guarantees — the case that stops the principle degenerating

Control name	PFCG organisational-level restriction
Product, module and release	S/4HANA on-premise — unspecified
Enforcement point	AUTHORITY-CHECK, per action
Type	preventive
Control subject	one action against one org unit
Observation boundary	single action / one principal / instant
Retained state	none
Local predicate	the action's org unit is in the grant
Property A	no part of the workflow touches an org unit outside the grant
Property B	—
Who claims them	the organisation

Closure	closed. If every out-of-unit action is refused, no sequence of permitted actions can leave the unit. The property is wider than the boundary and holds anyway
Audit status	not-yet-contested
Countermechanism	n/a — the control holds
Verdict	holds by compositional closure
Result	all 120 documents refused for the wrong company code

H3/G2 — The method refusing a result because the property was ours

Control name	GRC Access Risk Analysis (static, per principal)
Product, module and release	GRC Access Control — unspecified
Enforcement point	offline analysis of role assignments
Type	detective
Control subject	one principal's grant set
Observation boundary	sequence / one principal / period
Retained state	the grant set
Local predicate	no principal spans both sides of a conflicting pair
Property A	no principal holds both sides — the vendor's own stated property
Property B	no single decision process completes both sides — ours
Who claims them	A: SAP. B: the researcher. That difference is the whole finding
Closure	not applicable to B; the property ranges over principals the analysis never considers together
Audit status	contested — keeping property A is defensible and is what SAP claims
Countermechanism	ARA per principal and against the accumulating technical user, both tested. SAP Business Workflow not tested and is process-scoped
Verdict	A holds directly · B contested specification
Result	A: the technical user accumulating both grants is flagged. B: both propagated principals clean, composition completes — published as a proposed property, never as a failure

G3 — The method refusing a result twice

Control name	Security Audit Log record
Product, module and release	S/4HANA — unspecified
Enforcement point	after the fact
Type	evidentiary

Control subject	authenticated principal
Observation boundary	single action / one principal / instant
Retained state	the log
Local predicate	record the principal, transaction and time
Property A	name the accountable principal
Property B	attribute the action to the entity that SELECTED it
Who claims them	A: conventional audit practice. B: the researcher
Closure	not applicable — this is a subject mismatch, and no retained history repairs a non-injective map
Audit status	contested — A is a legitimate audit objective
Countermechanism	tested, late. Timing density, session identifiers and terminal fields were named in the pre-registration, left untried for eight days (loss L2), and finally measured in X12: retained history changes nothing where no recorded field separates the actors, and the best accuracy available to any procedure over the modelled record equals the do-nothing baseline
Verdict	contested specification
Result	blocked on two grounds — <i>contested specification</i> and <i>countermechanism untested</i> — one of which has since been cleared by doing the work rather than by arguing it away. What survives is a bound over one modelled evidence stream and a property nobody has agreed on

Related work, and what it costs this paper

Generated by python3 relatedwork.py. Do not edit by hand.

This section is placed before the results rather than after them, because it changes what the results are allowed to mean.

Rule 3 of the boundary map says a gap may not be published until the strongest existing countermechanism has been named and tested. Loss L3 generalises it: a control-surface review is incomplete until the strongest countermechanisms have been searched through independent retrieval routes. Neither rule had ever been pointed at the literature. The paper carried a formal object, a principle, an instrument and five experiments, and cited nothing — so the question rule 3 asks about mechanisms had never once been asked about ideas. This section is that question, asked late.

Every entry below states how the paper’s claim shrinks because the work exists. An entry that costs the paper nothing is not carried; the build refuses it.

The short version

The principle is not new. It is a specialisation of Schneider’s characterisation of enforceable security policies to controls whose observation boundary is narrower than the execution. Its extent form is the aggregation problem, named in 1989. Its repair — give the control state — is history-based access control, dynamic separation of duty, and the mutable attributes of UCON. Its closure refinement is the access-control shadow of the composability literature. Even the agent framing has a contemporary: an arXiv preprint from May 2026 names aggregation inference as one of three sub-problems of authorisation propagation in multi-agent systems.

4 of the 19 works below are marked as anticipating some part of what this paper was carrying as a contribution.

Anticipates — states some part of this paper’s contribution first

Fred B. Schneider. *Enforceable security policies*. ACM Transactions on Information and System Security (TISSEC) 3(1), 2000.

pages	30–50
doi	10.1145/353323.353382
fields read from	https://www.cs.cornell.edu/fbs/publications/EnfSecPols.pdf

What it says. Characterises exactly the class of security policies enforceable by mechanisms that monitor system execution, and gives security automata for specifying that class. Three conditions: the policy must be a PROPERTY, meaning membership is determined by each execution individually rather than by the set of executions; the allowed set must be prefix-closed in the safety sense, so a violated prefix cannot be repaired by any extension; and the violation must be detectable from a finite prefix. Information-flow policies are the named example of what falls outside, because they relate multiple executions.

What it costs this paper. This is the closest prior art in the paper and it takes a large piece of the contribution. The vocabulary for saying that a monitor cannot enforce what it cannot decide from what it observes has existed since 2000, and it is sharper than ours.

What is left after it is a difference of question rather than of answer. Schneider fixes the observation — an EM mechanism sees the whole execution prefix — and asks which policies are enforceable. This paper fixes the CONTROL, whose observation boundary was decided by whoever specified it and is usually far narrower than the execution, and asks which

properties that particular boundary can decide. The distinction is not academic here: the period-aggregate materiality property of G1 is a safety property of the execution and is EM-enforceable in Schneider's sense. A monitor watching the whole period would enforce it without difficulty. The FI tolerance group cannot, because its predicate reads one document. So the paper may not claim to have found a class of unenforceable policies. It may claim, at most, to apply the enforceable-policy question to deployed controls one at a time, which is a specialisation.

Teresa F. Lunt. *Aggregation and inference: facts and fallacies*. IEEE Symposium on Security and Privacy (S&P), Oakland, 1989.

pages	102-109
doi	UNVERIFIED
fields read from	https://conferences.computer.org/sp/pdfs/sp/1989/0004431

What it says. Examines inference and aggregation problems in multilevel relational database systems and argues that aggregation had been treated only superficially. The aggregation problem is that a collection of individually releasable items can require a classification higher than any item in it.

What it costs this paper. **Extent mismatch, in its purest form, is the aggregation problem under another name and in another control domain.** A set of individually-permitted actions producing an outcome no individual action would be permitted to produce is what G1 measures and what this paper spent five thousand words describing as though it were structural news. It is thirty-seven years old. The paper may claim the measurement and the location — that a mature ERP authorisation surface exhibits it on a specific posting path, and at what cost to legitimate work — and may not claim the phenomenon.

Michael J. Nash and K. R. Poland. *Some conundrums concerning separation of duty*. IEEE Symposium on Research in Security and Privacy (S&P), 1990.

pages	201-209 (DBLP) / 201-207 (OpenAlex) — DISPUTED, verify against the printed proceedings before citing
doi	10.1109/RISP.1990.63851
fields read from	https://dblp.org/rec/conf/sp/NashP90.html

What it says. Presents a dynamic separation-of-duty policy occurring in real commercial settings which can be implemented efficiently but cannot be implemented by mechanisms based solely on the TCSEC, and a financial-transaction-integrity product satisfying neither the TCSEC nor the Clark-Wilson rules.

What it costs this paper. The observation that a real commercial integrity policy outruns the control model available to enforce it — which is this paper's whole argument shape — is stated here, in finance, in 1990. The page range disagrees between two sources and is recorded as disputed rather than picked.

Daryl McCullough. *Noninterference and the composability of security properties*. IEEE Symposium on Security and Privacy (S&P), 1988.

pages	177-186
-------	---------

doi	10.1109/SECPRI.1988.8110
fields read from	https://api.openalex.org/works/doi:10.1109/SECPRI.1988.8

What it says. Shows that noninterference and several generalisations do not compose — two individually secure systems can be connected so that the composite is insecure — and introduces restrictiveness, a property that is composable, so that legally connected restrictive systems yield a restrictive system.

What it costs this paper. The compositional-closure refinement in `mismatch.py` — that an extent difference is a mismatch only where the property is not closed under the control’s local predicate — is the access-control shadow of this result. Composability is a property systems have to be designed to have, and cannot be assumed from the security of the parts. H2 is an instance of a closed case and the paper presented it as a refinement it had found. It is an instantiation.

Supplies — supplies the mechanism this paper’s repair recommendation amounts to

David F. C. Brewer and Michael J. Nash. *The Chinese Wall security policy.* IEEE Symposium on Security and Privacy (S&P), Oakland, 1989.

pages	206-214
doi	10.1109/SECPRI.1989.36295
fields read from	https://www.cs.purdue.edu/homes/ninghui/readings/Access

What it says. A mathematical theory for a commercial security policy in which access is history-dependent: datasets are grouped into conflict-of-interest classes and a subject’s prior accesses determine what it may access next. Shows the policy cannot be correctly represented in a Bell-LaPadula model.

What it costs this paper. The recommendation this paper’s G1 result leads to — give the control state that survives the individual action — is the shape Brewer and Nash formalised for commercial systems in 1989, in the same industry sector. The paper may not present a stateful control as a new proposal. It may report what a specific deployed surface does and does not offer on a specific path.

David F. Ferraiolo, Ravi Sandhu, Serban Gavrila, D. Richard Kuhn and Ramaswamy Chandramouli. *Proposed NIST standard for role-based access control.* ACM Transactions on Information and System Security (TISSEC) 4(3), 2001.

pages	224-274
doi	10.1145/501978.501980
fields read from	https://csrc.nist.gov/csrc/media/projects/role-based-access-control/documents/rbac-std-draft.pdf (NIST draft; TISSEC page proofs not fetched)

What it says. Unifies prior RBAC models into a reference model plus functional specification. Dynamic separation of duty is a standard component: where static SSD constrains permanent user-role assignment, DSD constrains role ACTIVATION within and across a user’s sessions and is enforced at activation time.

What it costs this paper. Sets the boundary of G2 precisely. DSD already constrains what one principal may activate across sessions, so the paper may not claim that deployed access-control standards ignore dynamic conflict. What X8 measures is narrower and survives: DSD is defined over a USER's sessions, and the composition in X8 is across two propagated principals in one agent workflow, which is not a user.

Jaehong Park and Ravi Sandhu. *The UCON_ABC usage control model.* *ACM Transactions on Information and System Security (TISSEC)* 7(1), 2004.

pages	128-174
doi	10.1145/984334.984339
fields read from	https://profsandhu.com/journals/tissec/ucon-abc.pdf

What it says. A family of core models unifying authorisations, obligations and conditions and subsuming MAC, DAC, RBAC, trust management and DRM. Two defining innovations, quoted from the authors: authorisations may be pre-authorisations or ONGOING authorisations evaluated while a right is being exercised; and subject and object attributes may be MUTABLE, changed as a consequence of access through pre-, ongoing- and post-updates.

What it costs this paper. **The repair this paper recommends for G1 already has a model, and it is twenty-two years old.** A cumulative credited-value limit is a UCON ongoing authorisation over a mutable accumulated-value attribute; that is what mutability was introduced for. The paper's recommendation is therefore not 'add a new kind of control' but 'the control model that expresses this has existed since 2004 and this posting path does not use it'. That is a weaker claim and a more useful one.

Martín Abadi and Cédric Fournet. *Access control based on execution history.* *Network and Distributed System Security Symposium (NDSS)*, 2003.

pages	UNVERIFIED (no page range in the NDSS or DBLP record)
doi	none assigned
fields read from	https://www.ndss-symposium.org/wp-content/uploads/2017/09/Access-Control-Based-on-Execution-History-Martin-Abadi.pdf

What it says. Argues that stack-inspection mechanisms for determining the runtime rights of code are inherently partial, and proposes a history-based model in which rights are determined by the attributes of all code that has run, together with explicit requests to augment rights.

What it costs this paper. The enforcement mechanism for an extent-mismatched control — carry the history rather than the current step — with an argument for why the narrower alternative is inherently partial. The paper's structural claim is a restatement of that argument in an authorisation surface rather than a language runtime.

Guy Edjlali, Anurag Acharya and Vipin Chaudhary. *History-based access control for mobile code.* *ACM Conference on Computer and Communications Security (CCS)*, 1998.

pages	38-48
doi	10.1145/288090.288102
fields read from	https://dblp.org/rec/conf/ccs/EdjlaliAC98.html

What it says. A history-based access-control mechanism maintaining a selective history of each program’s access requests, so that what a program may do depends on its own prior behaviour rather than only on its origin. Implemented in the Deeds system.

What it costs this paper. The same repair, implemented, five years earlier, and with the ‘selective history’ problem — which history is worth keeping — already identified as the hard part. This paper does not address that question at all and should not imply it has.

NextLabs, Inc.. *Data Access Enforcer for SAP ERP — dynamic authorization and attribute-based access control*. Vendor product documentation and datasheet, 2024.

pages	n/a
doi	none assigned
fields read from	https://www.nextlabs.com/products/data-access-enforcer/dynamic-data-protection-using-attribute-based-access-control-abac/

What it says. A commercial enforcement product for SAP that evaluates access at runtime against attribute-based policies every time data or an application is accessed, and filters, masks or blocks the result at the application and database layers accordingly. The same direction is taken by other enterprise ISVs — Saviynt and comparable identity-governance and fine-grained-entitlement platforms — moving enforcement from static SAP roles to conditional, per-request decisions on individual data items.

What it costs this paper. The repair direction this paper points to — relocate the control so that it observes the entity the property is about — is already instantiated in industry, so the paper may not present runtime, content-ranging, per-data-item authorization as a new idea. What survives, and what the existence of these products sharpens rather than removes, is the cumulative-over-time case. These enforcers evaluate each request on its own attributes, so they address the extent-over-content and extent-over-principal mismatches while a per-request decision that retains no accumulated state still cannot bound the G1 period aggregate. The one uncontested gap in this paper therefore survives even the strongest deployed tooling of this class unless that tooling is given state over the horizon the guarantee is defined on — which is the paper’s actual recommendation, now expressible against a concrete product rather than in the abstract.

Adjacent — asks a related question with a different object

Michael R. Clarkson and Fred B. Schneider. *Hyperproperties*. Journal of Computer Security (JCS) 18(6), 2010.

pages	1157-1210
doi	10.3233/JCS-2009-0393
fields read from	https://api.openalex.org/works/doi:10.3233/JCS-2009-0393 (conference version: CSF 2008, 51-65, 10.1109/CSF.2008.7)

What it says. Generalises trace properties to hyperproperties — sets of sets of traces — so that policies which are not predicates on individual traces, such as secure information flow and average-case service level agreements, become expressible. Safety and liveness both generalise, and every hyperproperty is the intersection of a safety hyperproperty and a liveness hyperproperty.

What it costs this paper. Fixes the boundary of what this paper is entitled to say about its own two forms. Neither is a hyperproperty. Extent mismatch concerns a property of a single execution that a narrow control cannot see all of, and subject mismatch concerns a single execution whose record does not carry the field the property is about. The paper must not reach for the hyperproperty vocabulary to make its results sound deeper than they are — and the X12 bound is a plain indistinguishability argument of the kind this literature has used for decades, not a new instrument.

Richard T. Simon and Mary Ellen Zurko. *Separation of duty in role-based environments.* IEEE Computer Security Foundations Workshop (CSFW), 1997.

pages	183-194
doi	10.1109/CSFW.1997.596811
fields read from	https://dblp.org/rec/conf/csfw/SimonZ97.html

What it says. Surveys applications of separation of duty, notes that computing implementations diverge from traditional practice with no agreed definition, introduces history-based considerations, and describes an implementation in the Adage authorisation toolkit.

What it costs this paper. G2 proposes a decision-layer separation property — that no single decision process should complete both sides of a conflicting duty pair. The observation that deployed separation of duty diverges from what practitioners mean by it, and that history is what closes the difference, is this paper. G2's contribution is therefore not the observation but the specific substitution the counterfactual audit caught us making.

John McLean. *A general theory of composition for trace sets closed under selective interleaving functions.* IEEE Symposium on Research in Security and Privacy (S&P), 1994.

pages	79-93
doi	10.1109/RISP.1994.296590
fields read from	https://api.openalex.org/works/doi:10.1109/RISP.1994.296590

What it says. A general theory of composition for possibilistic security properties, observing that they fall outside the Alpern-Schneider safety/liveness domain and are therefore not subject to the Abadi-Lamport composition principle. Closure under selective interleaving functions is generally preserved by product and cascading but not by feedback, internal composition or refinement.

What it costs this paper. Supplies the warning this paper needs about its own closure test. Closure is preserved by some compositions and not by others, so `closed_under_composition` as a single boolean is coarser than the literature it echoes, and the paper must say so rather than let the field's simplicity imply the question is simple.

Heiko Mantel. *On the composition of secure systems*. IEEE Symposium on Security and Privacy (S&P), 2002.

pages	88-101
doi	10.1109/SECPRI.2002.1004364
fields read from	https://api.openalex.org/works/doi:10.1109/SECPRI.2002.1004364

What it says. Compositionality results for security properties, including a composable property weaker than forward correctability, and a demonstration that certain non-trivial properties emerge under composition. All results derive from one general lemma which also reproves and classifies earlier compositionality results.

What it costs this paper. That properties can EMERGE under composition is the mirror image of this paper's argument and it is not addressed anywhere in these experiments. The sweep asks only whether a harm survives; it never asks whether composing two controls creates a guarantee neither has alone. That is an omission and belongs in the research programme.

Claudio Bettini, Sushil Jajodia, X. Sean Wang and Duminda Wijesekera. *Provisions and obligations in policy management and security applications*. International Conference on Very Large Data Bases (VLDB), 2002.

pages	502-513
doi	10.1016/B978-155860869-6/50051-2
fields read from	https://dblp.org/rec/conf/vldb/BettiniJWW02.html (bibliographic fields only; the VLDB PDF refused retrieval and the abstract is UNREAD)

What it says. UNVERIFIED — the abstract was not fetched, so no claim is made here about what the paper argues. The entry is carried for the distinction its title names, not for its content.

What it costs this paper. X11 forced this paper to separate preventive from detective coverage for the first time, and the provision/obligation distinction is the policy-language vocabulary for exactly that split. The paper should not present the separation as one it invented. Because the abstract is unread, this entry may be cited for the existence of the distinction and for nothing else.

Qun Ni, Elisa Bertino and Jorge Lobo. *An obligation model bridging access control policies and privacy policies*. ACM Symposium on Access Control Models and Technologies (SACMAT), 2008.

pages	133-142
doi	10.1145/1377836.1377857
fields read from	https://api.openalex.org/works/doi:10.1145/1377836.1377857

What it says. An obligation model for privacy-aware RBAC supporting pre-, post-, conditional and repeating obligations, with algorithms to detect undesired interactions between permissions and obligations.

What it costs this paper. Obligations that must be discharged after an action are the formal counterpart of the detective step T6 in X11, whose measured result is forty of forty flagged and forty of forty in production. The paper may report that measurement; it may not imply that the preventive/detective asymmetry is a new observation.

Harold Booth, Bill Fisher, Ryan Galluzzo and Joshua Roberts. *Accelerating the adoption of software and AI agent identity and authorization.* NIST National Cybersecurity Center of Excellence, concept paper (draft), 2026.

pages	n/a
doi	none assigned
fields read from	https://www.nccoe.nist.gov/sites/default/files/2026-02/accelerating-the-adoption-of-software-and-ai-agent-identity-and-authorization-concept-paper.pdf

What it says. Proposes a NIST project applying existing identity standards — OAuth 2.0, SPIFFE/SPIRE, NGAC — to identification, authentication, authorisation and logging for AI agents in enterprise environments with human oversight. Does not mention ERP.

What it costs this paper. Fixes what ‘enterprise’ currently means in standards work on agent authorisation: identity infrastructure, not the business-application control surface an agent actually acts through. The paper’s choice of object is defensible against this and should be argued rather than assumed.

Contemporary — concurrent work on the same problem

Krti Tallam. *Authorization propagation in multi-agent AI systems: identity governance as infrastructure.* arXiv preprint arXiv:2605.05440, 2026.

pages	n/a
doi	arXiv:2605.05440
fields read from	https://arxiv.org/abs/2605.05440

What it says. Formalises authorisation propagation as a workflow-level property not reducible to prompt injection and not covered by RBAC, ABAC or ReBAC, and names three sub-problems: transitive delegation, AGGREGATION INFERENCE, and temporal validity, from which seven structural requirements are derived.

What it costs this paper. The closest contemporary work, and it names the aggregate problem for agent systems three months before this paper. The paper may not claim to be first to identify aggregate authorisation as an agent-specific structural problem. What is not in it, as far as this search can tell, is measurement: no control surface is swept, no harm predicate reads world state, and no verdict is withdrawn under audit. This paper’s claim narrows to the empirical half.

Xinfeng Li, Dong Huang, Jie Li, Hongyi Cai, Zhenhong Zhou, Wei Dong, XiaoFeng Wang and Yang Liu. *A vision for access control in LLM-based agent systems.* arXiv preprint arXiv:2510.11108, 2025.

pages	n/a
-------	-----

What it says. A position paper arguing that static rule-based access control is ill-equipped for agentic information flows, and proposing Agent Access Control: dynamic, context-aware information-flow governance with adaptive responses such as redaction and summarisation rather than binary allow/deny.

What it costs this paper. Establishes that ‘static access control is the wrong shape for agents’ is a position already in the literature and already argued generically. This paper’s difference is that it names one deployed surface, sweeps it exhaustively, and reports the exchange rate. The difference is evidence, not thesis.

What was not found

A search of arXiv, OpenAlex, DBLP, Semantic Scholar and the open web found no peer-reviewed or preprint work on the security or authorisation of autonomous agents acting specifically in ERP or SAP systems. The agent-authorisation work that exists is domain-generic; the ERP-plus-agents work that exists is about capability and architecture rather than control. **This is reported as the result of one bounded search, not as an absence.** The same asymmetry the specification-sensitivity audit insists on applies here: finding nothing is evidence about the search.

What was not read

source	what it costs
IEEE Xplore and the ACM Digital Library	refused automated retrieval, so abstracts for several entries were read from OpenAlex reconstructions or author-hosted preprints rather than from the publisher’s page of record. Where the two disagreed the disagreement is recorded in the entry.
help.sap.com and community.sap.com	refuse automated retrieval, which is loss L3 unchanged. Two SAP-authored community posts on securing agentic AI and on propagating user identity from Joule into S/4HANA were found by title and could not be read. They are the highest-value unread sources for this paper and they bear directly on whether the modelled surface resembles the current one.
Workflow authorisation models	were not searched systematically. G2’s decision-layer property is a workflow-level separation constraint, and there is a literature on workflow authorisation this file does not cover. That is a known hole, named here rather than left for a reviewer.
Bettini et al. 2002	is carried on bibliographic fields alone; its abstract was not fetched, and the entry says so.

What is left

After all of the above, this is what the paper may still claim.

The instrument, not the principle. The Control-Property Review is a decision procedure a practitioner can run against a named control and a named property, and four of its seven verdicts are refusals. Schneider’s characterisation tells you what a monitor can enforce; it does not tell a security architect holding a PFCG role and a materiality threshold what to do on a Tuesday. Whether an instrument is a contribution is a fair question, and it is the question the paper should be defending.

The specification-sensitivity audit. Naming, for every verdict, the smallest defensible alternative specification that would flip it — and marking the verdict **CONTESTED** when that alternative is consistent with independent evidence. Four of eight pairs come back contested, including two the paper wanted to publish. This search found no precedent for it as a stated protocol. That is a bounded search and the asymmetry applies: no precedent found is not no precedent.

The measurement, and the exchange rate. The aggregation problem is old; what it costs on a specific posting path in a specific reconstructed authorisation surface is not recorded anywhere this search could find. 12,288 configurations, 10,398 holding the outcome below materiality, best legitimate throughput 37.5%, and a one-to-one exchange between harm reduction and refused work. Numbers are what this paper has that the prior art does not.

The distinction between the two forms, and what claiming it cost. X7 and X11 measure one organisation’s controls against harms of the two different shapes, and the difference between them is not that one control is cheap and the other expensive. Where the property outruns the control’s extent, the exchange rate between harm and refused legitimate work is forced by the pair: the workloads are identical on the dimension the control reads, so every predicate over it removes the same proportion of each, and no implementation can do better. Where the control reads the property’s own subject, nothing is forced and the cost is set by that decision’s false-positive rate. Arriving at that distinction cost a retraction — the first version of X11 had no false-positive channel at all and reported zero cost as a measurement, which is loss L6 — and the surviving claim is narrower than the one it replaced.

The negative results. Two verdicts withdrawn under audit, one prediction respecified before running and then narrowed by its own result, one experiment whose procedure produced two rounds of artefacts before it produced a result, and a loss register that grew during the writing. Reporting these is not a contribution to knowledge about SAP. It is the reason the rest should be believed.

Part Three — The evidence

The SAP arm — results

Generated by `python3 run.py`. Do not edit by hand.

Pre-registered in PREREG_SAP.md before any of this existed. Every authorisation mechanism below was reconstructed from secondary sources: at the time these experiments were registered and run, the automated retrieval route had not yielded the required SAP documentation and no primary vendor material had been incorporated. **These are results about that reconstruction, and that remains permanently true of them.** The project's current evidence state is tracked separately in PREREG_SAP.md and has since advanced; see loss L3 and determination D1.

X7 — the missing rate limiter

Result: the pre-registered WEAKENING outcome. The claim as written — that a per-step model *cannot express* a constraint on outcome — is too strong and is withdrawn. What replaces it is smaller and sharper.

Setup

legitimate workload	120 customer credit memos, company code 1000, document type DG, amounts 200-5000
harmful sequence	400 further memos, same distribution, same company code, same document type, same activity
difference between them	count, and nothing else — enforced in code by <code>assert_indistinguishable()</code>
harm predicate	cumulative credited value in the period exceeds materiality (500000), read from the ledger
configuration space	12288 points: activity, company code, document type authorisation group, per-document tolerance, per-line tolerance

The tolerance dimensions matter. FI tolerance groups are the strongest value-based per-step control in the modelled surface, and they are included precisely so the claim could lose.

The sweep

	value
configurations evaluated	12288
configurations that keep the outcome below materiality	10398
best legitimate throughput among those	37.5%
clean separation ($\geq 95\%$ throughput retained)	no
legitimate value per period	294915
value posted in the attacked session, unconstrained	1384116

Ten thousand configurations hold the outcome below materiality. Every one of them does it by refusing between three-fifths and all of the legitimate work. The best configuration found — per-document tolerance 3,000 — keeps 37.5% of the business running.

Sensitivity to the one number we chose Materiality is the only figure here that was picked rather than measured, so the result is reported as a function of it.

materiality	as a share of the attacked session	best legitimate throughput
200000	14.4%	16.6%
350000	25.3%	26.2%
500000	36.1%	37.5%
650000	47.0%	37.5%
800000	57.8%	50.0%

The two right-hand columns track each other to within the granularity of the amount grid. That is the finding, and it is structural rather than numerical:

Because the harmful and legitimate documents are indistinguishable per document, any per-document predicate removes the same proportion of each. The per-step surface can buy a reduction in the harm only by buying an equal reduction in the work. The exchange rate is one to one.

So the authorisation model *can* bound the outcome. It bounds it the way a fuse bounds a fire. What it cannot do is discriminate, and discrimination is the entire content of the word *control*.

Instrument check (positive control) Pre-registered. The same sweep, against a harmful sequence whose amounts lie entirely above the legitimate band, **must** find a separating tolerance. If it cannot, the sweep is broken and the primary result means nothing.

	value
configurations that prevent the harm	12126
best legitimate throughput among those	100.0%
clean separation	yes

```
SapConfig(actvt=frozenset({'01'}), buks=frozenset({'1000'}), blart=frozenset({'DG'}),
per_doc=inf, per_line=10000.0, period_budget=None)
```

The instrument works. When a per-document difference exists, the sweep finds it and loses nothing. The primary arm's failure is therefore about the primary arm, not about the method.

The repair, and what it costs A cumulative per-principal budget over the period is not expressible in the modelled surface. Added as a separate control and run through identical machinery:

	value
budget settings tested	4
that prevent the harm	4
legitimate throughput under normal operation	100.0%
legitimate documents posted during the attacked session	40 of 120

This is the part a vendor slide would omit. Under normal operation the budget is invisible: full throughput, no friction. Under attack it works — and it works by spending itself on whatever

arrives first, so 80 of 120 legitimate documents are refused as collateral. The control converts a silent aggregate fraud into a loud partial outage. That is a better failure, and it is still a failure, and an architect deciding whether to deploy it deserves to be told which one they are buying.

Does the generic agent-security stack close it? No. The same session, run through the book’s own testbed with every one of its controls enabled — strict egress, verb scope, resource scope, payload-visible approval, descriptor pinning, memory provenance, ephemeral credentials, signed-head audit, information-flow labelling, sink-side DLP, memory quarantine, external baseline:

	value
calls attempted	520
executed	520
blocked	0
value posted	1384116

Every control fires on a property of the individual action. None of them holds a counter. This is not a criticism of the stack that would be unfair to make of published guidance either — it is the same absence, found in our own work, which is the only reason it is worth reporting.

X8 — composed authority across propagated principals

Result: the claim holds, and the interesting finding is not the one that was pre-registered.

principal	Access Risk Analysis
AP_CLERK (propagated)	clean
TREASURY (propagated)	clean
RFC_AGENT (technical user holding both grants)	P001: fictitious payee

The agent alters a vendor’s bank details in one session under one human’s propagated identity, and executes the payment run in a second session under another’s. Each principal is individually clean. The payment reaches the attacker’s account: XX99 ATTACKER.

Two things must be said about this before it is allowed to sound like a discovery.

First, it is close to definitional. A static predicate over grants cannot see a composition across grants; that follows from the word *static*. The pre-registered instrument check confirms the harm is real and pre-existing — two colluding humans produce it identically (**confirmed**) — which means agents introduce no new harm here. What they change is the price. Collusion requires two people to agree. Composition requires one agent to have been given both sessions, and nobody has to agree to anything.

Second, and this is the part worth the chapter: **the safer-looking architecture is the one that defeats the analysis.** Principal propagation — the design secondary material attributes to Joule, and the one any reviewer would prefer, because it means the agent holds no standing authority of its own — produces two individually clean principals and an invisible composition. The technical user, which looks worse on every checklist because it accumulates grants, is the one Access Risk Analysis can see. The control rewards the architecture that gives it something to look at.

X9 — attribution

Pre-registered as definitional. Reported as definitional. It is in the register so that its status was fixed before the numbers made it tempting to call it a finding.

	value
log records written	520
actions attributable to an actor, as logged	0
...with one additional field	520

A record identifies a principal. Under principal propagation the principal is the human. The record correctly identifies the authenticated principal but carries no separate identity for the autonomous process that selected the action. If the principal field is interpreted as naming the decider rather than the accountable principal, the selection is consequently assigned to the named employee.

The repair is one field. The value of this experiment is entirely in that sentence, and it may not be used to support X7 or X8.

X11 — the transport-governance surface

Result: the pre-registered WEAKENING outcome, and the third branch as well. The standing prediction P1 held at the pair it names and is narrowed by the same experiment that confirmed it.

P1 predicted that release authorisation cannot discriminate a harmful transport. The specification-sensitivity audit ruled that prediction misspecified — release authorisation never claimed behavioural safety — and required it respecified against the whole governance surface before it could be run. This is that experiment.

The surface

step	ranges over	placement	enforced by
T1 Release authorisation (S_TRANSPRT, ACTVT 43)	request	preventive	system
T2 Static check variant run at release (ATC / Code Inspector)	content	preventive	system
T3 Peer review of the change before release	content	preventive	human
T4 Release approval step (approver identity and role)	request	preventive	system
T5 Functional exercise in the quality system before import	content	preventive	human

step	ranges over	placement	enforced by
T6 Post-import comparison against the reviewed baseline	content	detective	system

Setup

legitimate arm	40 transports, benign objects
harmful arm	40 transports carrying a change to an FI validation exit that stops the tolerance predicate firing
difference between them	what an object does once active, and nothing else — same owner, target, request class, object types and object count, enforced by <code>assert_transport_indistinguishable()</code>
harm predicate	a harmful object active in production
configuration space	12,800 points: which of the six steps are switched on, whether the static-check catalogue contains a rule for this harm class, human review coverage, quality-system test coverage, and the rate at which a content step stops a BENIGN transport

The harmful behaviour attacks this paper’s own principal finding. If it reaches production the tolerance control measured in X7 stops firing, which is the least self-serving harm available to us.

On the false-positive rate. The first version of this experiment had no such parameter, so a content-ranging step was a perfect oracle: it stopped every harmful transport and no legitimate one, in every configuration. That produced a striking table which this section reported as a measured contrast against X7, and it was a property of the construction. It is loss L6. The parameter is now swept across four values and **none of them is measured** — no claim below rests on any particular one.

The sweep

	value
configurations evaluated	12,800
configurations that discriminate (harm stopped, $\geq 95\%$ of legitimate transports retained)	2,512
...that stop discriminating if the static catalogue does not carry the harm	1,296
configurations whose active steps range only over the REQUEST	800
...that discriminate	0
...harmful transports reaching production in the best of them	40 of 40

	value
configurations whose only content-ranging step is DETECTIVE	800
...that discriminate	0

Positive control: passed — in 224 configurations with release authorisation active and a principal lacking S_TRANSPRT ACTVT 43, every transport was refused.

Where the prediction narrows

minimal content-ranging preventive steps	configurations	needs the catalogue	minimum review coverage	minimum test coverage
T2	400	yes	0%	0%
T3	160	no	100%	0%
T5	160	no	0%	100%
T2, T3	480	no	0%	0%
T2, T5	480	no	0%	0%
T3, T5	288	no	0%	0%
T2, T3, T5	544	no	0%	0%

The surface contains decisions that range over the property's own subject, so the prediction narrows: the mismatch is real at the authorisation object and is covered elsewhere in the same surface. That is a control-placement finding of the same shape as Availability Control, and transport leaves the list of open mismatches.

Three things the sweep says that the narrowing does not **Coverage is a parameter, not a guarantee.** With the static catalogue assumed not to contain a rule for this harm class, human review is the only preventive content decision left, and the harm reaching production falls linearly with how much of the change somebody reads:

review coverage	harmful transports in production
0%	40 of 40
25%	30 of 40
50%	20 of 40
75%	10 of 40
100%	0 of 40

What it costs is not a property of the pair. This is the point the first version of this experiment got wrong. In X7 the price of reducing harm is forced: the two workloads are per-document identical, so every per-document predicate removes the same proportion of each and no configuration escapes the one-to-one exchange. Here the price is not forced by the control-property pair at all. It is whatever the content decision's false-positive rate happens to be, and the model neither measures that rate nor can.

a content step stops this share of benign transports	configurations	of which discriminate	legitimate throughput
0%	3,200	1,256	100-100%
5%	3,200	1,256	95-100%
10%	3,200	0	90-100%
25%	3,200	0	75-100%

At a five percent false-positive rate the surface still meets the 95% bar X7 was held to. At ten percent nothing does. **So the honest form of the contrast is not that one control is cheap and the other expensive.** It is that an extent mismatch makes the exchange rate a property of the control-property pair, which no implementation can improve, while a subject match makes it a property of the implementation, which a bad one can squander. That is a smaller claim than the one this section carried a day ago and it is the one the evidence supports.

Detection is not prevention, and the surface separates them cleanly. In the configurations whose only content-ranging step runs after the import, 40 of 40 harmful transports are flagged and 40 of 40 are in production. Perfect detection, zero prevention. The paper has not had to make that distinction anywhere else and now has to make it here.

What this is not. Whether SAP's delivered check variants contain a rule matching this harm class is not answered here. It is swept as a parameter and reported on both branches: on the branch where the catalogue does not carry it, 608 of 6,400 configurations still discriminate, and every one of them does so through a human step whose coverage nothing enforces.

X12 — attribution from correlates

Result: the pre-registered STRENGTHENING outcome. This is the experiment loss L2 records as pre-declared and never run, and it tests the half of the principle that is not about extent: the claim that a non-injective subject map is a projection failure rather than a memory failure.

Setup

session	512 actions by k concurrent actors behind one propagated principal
swept	actor count, interleaved or serialised, clock resolution, whether the terminal names the actor, whether the transaction code does, idle gap between serialised blocks, and how many preceding records the responder may hold
conditions responder	512, of which 384 have more than one actor partitions by the fields that name an origin, then splits on temporal discontinuity where the retained gaps are bimodal; scored on its best possible relabelling

Positive control: passed — every one of the 128 single-actor conditions attributed perfectly (worst 1.000). A procedure that cannot name the actor when there is one candidate would make the rest meaningless.

Does retained history repair it?

actors	retention 1	10	100	whole period
2	0.500	0.500	0.500	0.500
4	0.250	0.250	0.250	0.250
8	0.125	0.125	0.125	0.125

Those are the conditions principal propagation actually produces: one technical user, one terminal, one transaction code, actions interleaved, whole-second stamps. Accuracy is exactly $1/k$ and exactly flat. Across all 96 condition groups, retention changed the outcome in 28 of them — and in **0 of the 18 groups where no recorded field separated the actors, retention changed nothing at all**. The best accuracy reached anywhere in those groups is 0.500, which is chance.

So retention does help — in 28 groups it moved the result materially — and in every one of those a separating field was already present for it to exploit. Retention improves how well an existing signal is used. It does not create one. That is the clause the formalism makes, stated more precisely than the formalism stated it.

how the 264 successful conditions succeeded	count
a field that names the origin (terminal or transaction code)	264
serialised execution with an idle gap between actors	0
neither	0

The bound, and the practitioner’s objection A procedure that fails is weak evidence; the reply is always that a better one would have worked. So the primary instrument is not a procedure. Two records carrying identical observable fields are the same record to any procedure, which must answer the same for both. The best achievable accuracy is therefore fixed by the evidence rather than by anyone’s cleverness — and loss L4 records why that matters here.

actors	upper bound on any procedure	majority baseline	ours
2	0.650	0.500	0.500
4	0.422	0.250	0.250
8	0.311	0.125	0.125

The bound sits above what our procedure achieved, so we do not claim it is optimal. It also sits far below one.

The objection G3 actually has to answer is different and blunter: *an agent posting hundreds of documents in minutes is obviously not a person, and you never checked*. One human and one agent, same principal, same terminal, same transaction code, with the agent’s action rate swept:

agent posts every	records	upper bound on any procedure	majority baseline	machine-speed activity detected
0.125s	48200	0.9959	0.9959	yes
1.000s	6200	0.9677	0.9677	yes
5.000s	1400	0.8571	0.8571	yes

agent posts every	records	upper bound on any procedure	majority baseline	machine-speed activity detected
10.000s	800	0.7500	0.7500	yes
30.000s	400	0.5000	0.5000	yes
60.000s	300	0.6667	0.6667	yes

The bound equals the majority baseline at every rate, to four decimal places. No procedure reading principal, transaction code, terminal and timestamp can attribute a single action better than answering *the busiest actor* for every record without reading anything at all. **The practitioner is right that you can tell an agent was there, and wrong that this attributes the action.** The density signal is a presence test, and the last column is honest about its own weakness: it fires in all six rows, including the two where neither actor exceeds human speed, so it is detecting aggregate load rather than machine speed.

What survives is a bound over one modelled evidence stream. Change documents, table logging and read-access logging were not modelled, and a correlate in any of them would narrow this further.

Figures

Generated by *python3 figures.py*. Do not edit by hand. Every coordinate, label and count below is read from the sources; none is typed.

Pair G1 — FI tolerance group (per-document / per-line amount)

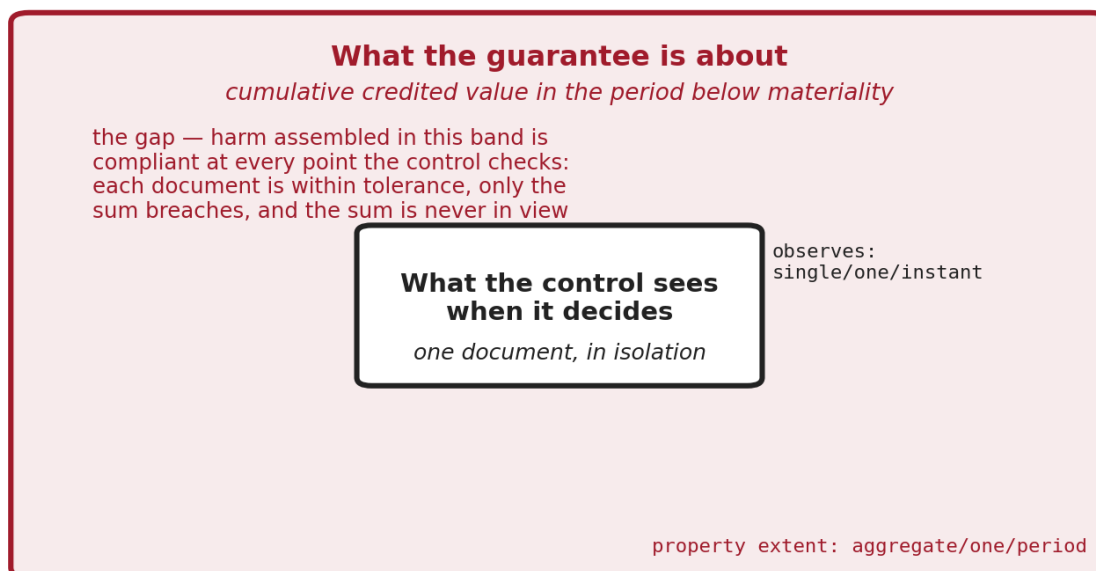


Figure 1. The mismatch, before any data: what a control sees against what its guarantee is about. The plain picture behind the whole paper, drawn for the decisive pair G1. The small box is everything the FI tolerance group sees at the moment it decides — one document, in isolation. The large box is what the organisation’s materiality guarantee is actually about — the cumulative credited value across every document in the period. Harm that lives in the band between the two boxes is compliant at every point the control checks, because each document is individually within tolerance; only the sum breaches, and the sum is never in the control’s view. That band is the gap the rest of the paper measures.

Autonomy amplifies a latent mismatch along four axes at once

a property past the boundary the control can see

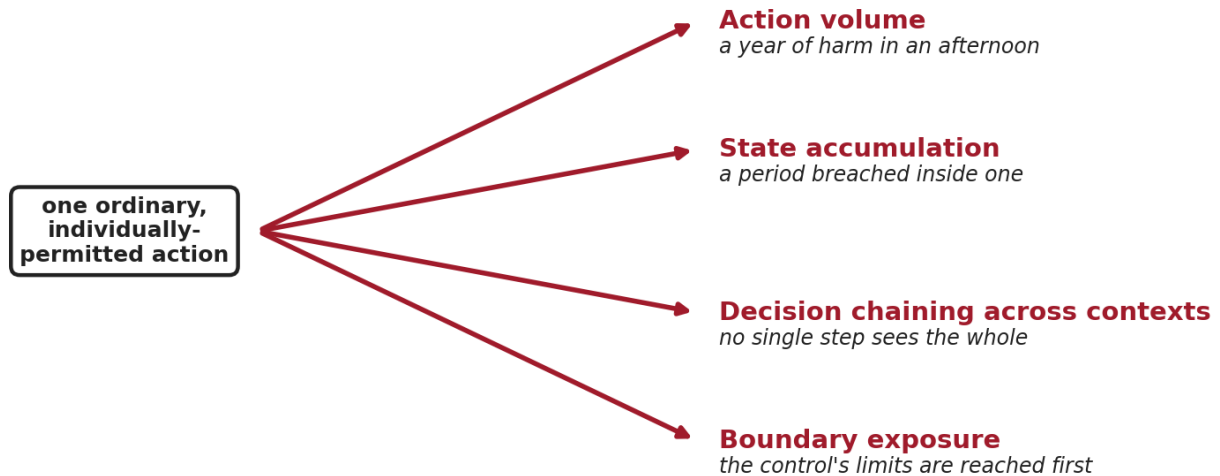


Figure 2. The four axes along which autonomous execution amplifies a latent mismatch. Autonomy does not create a control-property mismatch; it amplifies a latent one along four independent axes. From one ordinary, individually-permitted action, autonomous execution raises the volume of such actions, accumulates state a per-action control never retains, chains decisions across sessions and principals so no single step sees the whole, and reaches the limits of what each control observes faster than any human workload would. Only the first depends on throughput; together they push a property past the boundary the control can see.

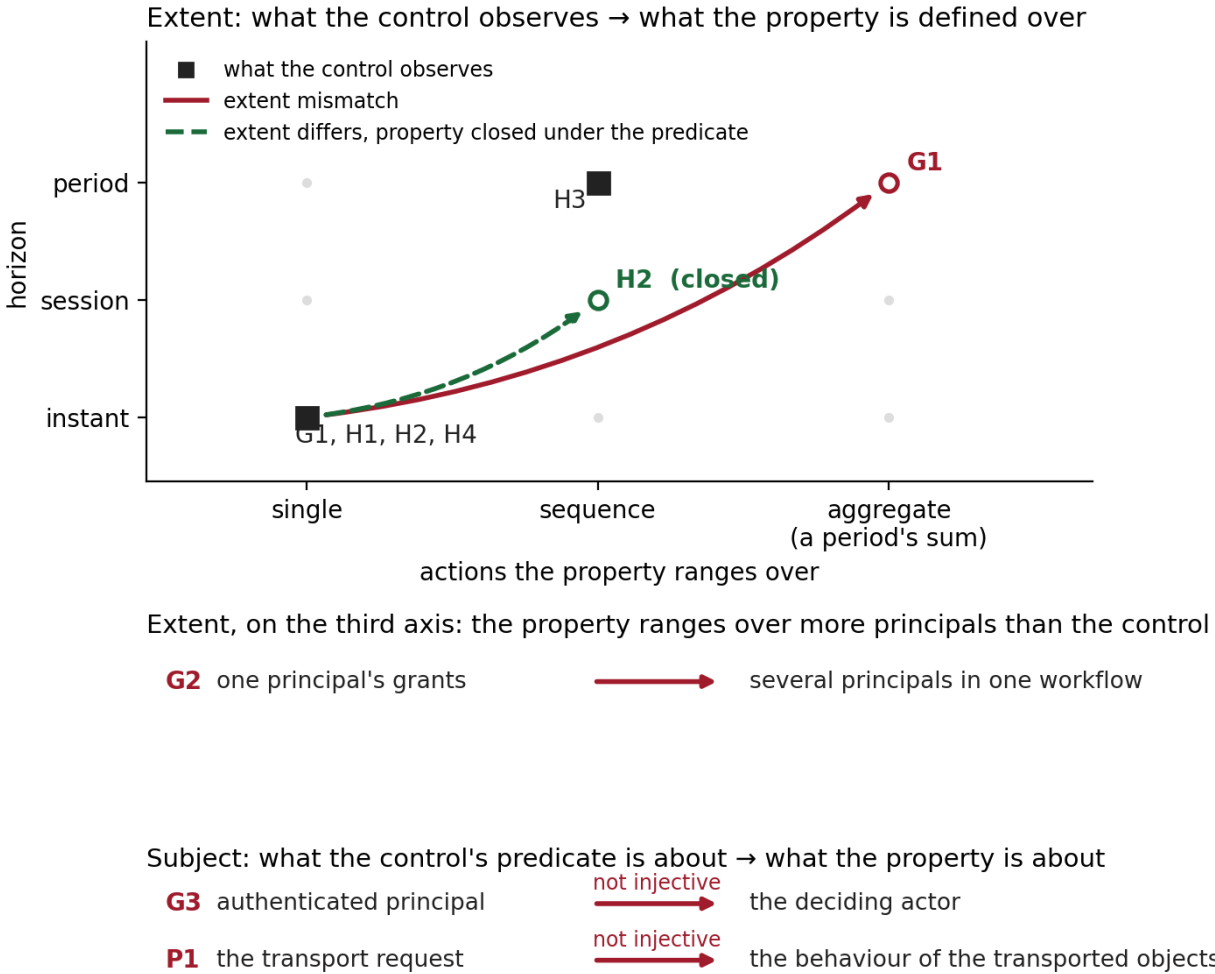


Figure 3. The observation boundary against the property's extent. Each arrow runs from what a control observes at decision time to what its protected property is defined over. Solid arrows are extent mismatches; the dashed arrow is H2, where the extents differ and the property is closed under the control's local predicate, so the control still guarantees it. H1 and G1 are the same SAP control — an FI tolerance group — against two different properties, which is why one sits on the origin with no arrow and the other reaches the far corner. The two rows beneath carry the breaks this plane cannot draw: G2's property outruns its control on principals, and G3 and P1 have identical extents and break on subject instead. Drawing those below rather than forcing them onto these axes is deliberate — a figure that made both forms look like the same picture would be arguing by illustration.

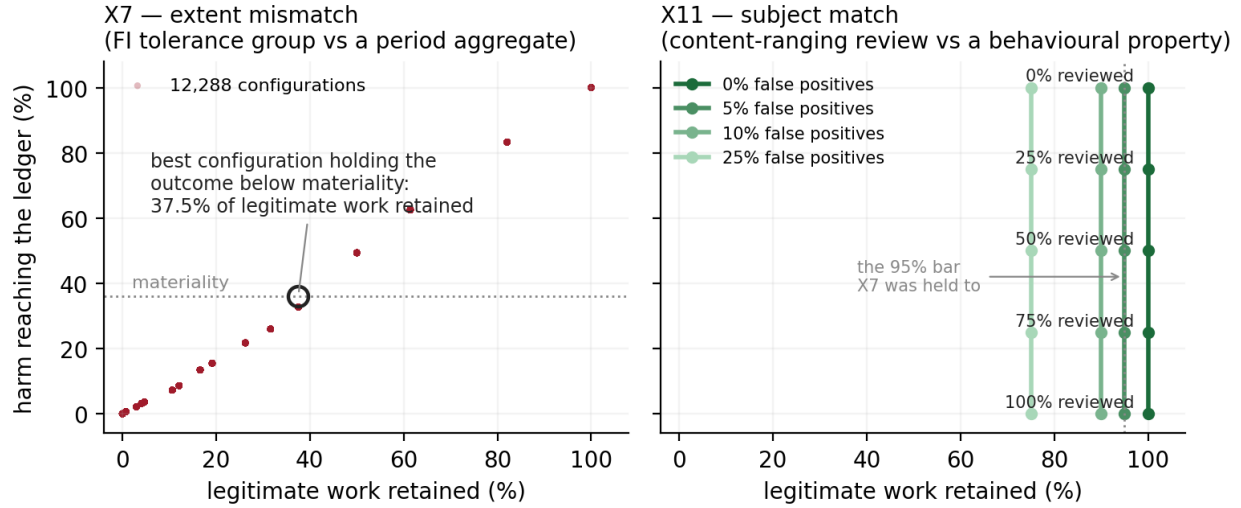


Figure 4. What each kind of mismatch costs to close, and what sets the price. Left: every configuration of the modelled FI authorisation surface, each plotted as the harm it admits against the legitimate work it retains. They collapse onto a line through the origin, and that line is not fitted: because the two workloads are per-document identical, any per-document predicate removes the same proportion of each, so a point below the materiality line is bought one-for-one in refused legitimate work. No implementation escapes it. Right: the same axes for the transport surface, where the discriminating decision reads the property’s own subject — one track per false-positive rate, because that rate and not the control-property pair is what sets the price here. The earlier version of this panel plotted only the zero-rate track and captioned it as a measurement of what a subject-matched control costs. It was a property of the model, it is loss L6, and the remaining tracks are what the retraction bought.

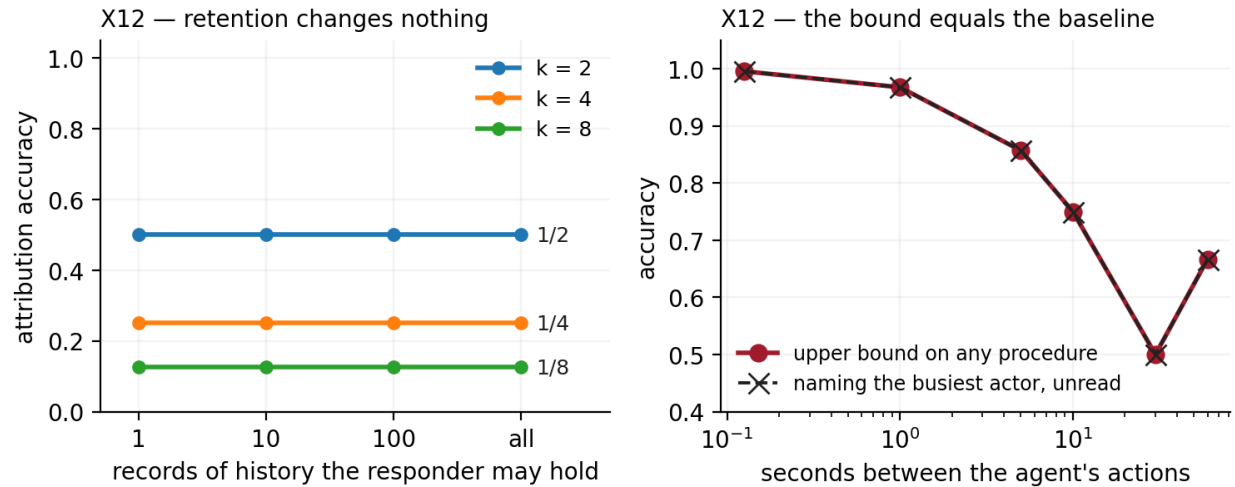


Figure 5. Attribution accuracy under principal propagation. Left: accuracy against how much history the responder is allowed to hold, for two, four and eight concurrent actors behind one propagated principal, in the conditions principal propagation actually produces. The lines are flat and sit on $1/k$. Right: the upper bound on ANY procedure reading principal, transaction code, terminal and timestamp, against the accuracy of naming the busiest actor without reading anything, for one human and one agent at each agent action rate. The two are equal at every rate.

The boundary map

Generated by *python3 boundary.py*. Where a reconstruction of four decades of deployed control engineering absorbed autonomous execution without needing a new security object, and where it did not.

The five rules

Referred to by number elsewhere in this paper, and printed here so the reference resolves. Every one of them is checked by the build.

	rule	how it is enforced
1	Parity of resolution. A control that held must be reported at the same evidentiary depth as a control that failed.	the two registers' mean evidence length is compared, and the build fails when the held register is materially thinner
2	Every success carries its architectural interpretation. <i>Not this control blocked it but a control already governs the variable the autonomous sequence tried to create harm on</i> — which is what lets the held register refine the first book rather than flatter the vendor.	an interpretation shorter than twenty-five words is rejected as a summary
3	A gap may not be published until the strongest existing countermechanism a practitioner would reasonably claim closes it has been named AND tested.	admissible is false unless strongest_alternative_tested is true; this rule blocked G3 for eight days
4	"Not found" is not "does not exist". Every record carries one of six evidence statuses and those two are different values.	an unknown status fails the build
5	The registers are named, never numbered.	no source may refer to the held or gap register by chapter number; that numbering collided with the chapter table once and no check could see it

Controls that held

H1 — FI tolerance groups (per-document and per-line amount limits)

failure definition	A fraudulent posting whose value lies outside the range of ordinary business for the principal making it.
--------------------	---

strongest attack attempted	400 credit memos of 20,000-50,000 each, interleaved with the legitimate workload in a single agent session — 1.2m of harm against a materiality threshold of 500,000.
mechanism that blocked it	ToleranceGroup.amount_per_document and amount_per_line, evaluated per user per company code, refusing the document before it posts.
intervenes at configuration assumptions	action The limit must actually be set. The sweep's default of unbounded blocks nothing, and an unbounded tolerance group is a configuration a practitioner would recognise as wrong — which is the point: this control works and is routinely left open.
operational cost	None measured. 100% of the legitimate workload posted with the separating configuration in place.
generalisation boundary	Holds only while the harmful amounts lie outside the legitimate distribution. When the two overlap, the same mechanism at its best setting retains 37.5% of legitimate throughput (X7). The control is not weak; the variable it ranges over stops matching the harm.
evidence status	<i>found only in secondary material; no primary source read</i>
reproduce	python3 verify.py — the mutation test neuters ToleranceGroup.permits and the positive control stops separating.

What the success means. In the modelled surface a control already governs the variable — document value — on which this autonomous sequence attempted to create harm, and no new security object is required for value-based fraud there. Whether the deployed mechanism has the same shape is the open question M2 names. What agents change is not whether value is governed but whether value is the variable the harm is expressed in.

H2 — PFCG organisational-level restriction (AUTHORITY-CHECK)

failure definition	An action taken against an organisational unit outside the authority the task was granted.
strongest attack attempted	The full legitimate workload posted into company code 1000 by a principal authorised only for 2000.
mechanism that blocked it	AUTHORITY-CHECK on F_BKPF_BUK, evaluated per authorisation INSTANCE rather than by unioning field values across instances.
intervenes at	action

configuration assumptions	The per-instance semantics are load-bearing and easy to model wrongly. A union model — passing if BUKRS is permitted somewhere and ACTVT is permitted somewhere — is strictly more permissive than SAP and would have manufactured a finding. Tested explicitly.
operational cost	None. Zero legitimate documents refused.
generalisation boundary	Ranges over the organisational unit and the activity. Says nothing about volume, sequence, or content, and is not weakened by agents in any way we could construct.
evidence status	<i>found only in secondary material; no primary source read</i>
reproduce	python3 verify.py — neutering Authorization.permits unblocks the wrong company code; the real check blocks all 120 documents.

What the success means. This is the control the first book models as C2 and C10 together, and the modelled version is finer than either. Where the first book found verb-level scope insufficient and resource-level scope necessary, the reconstructed surface carries resource-level scope as a matter of course. That is a first-book recommendation arriving as a solved problem — in the reconstruction — and the held register should say so plainly.

H3 — GRC Access Risk Analysis against an accumulating principal

failure definition	A single principal holding both sides of a conflicting duty pair.
strongest attack attempted	A technical user, RFC_AGENT, holding the AP clerk’s vendor-master grant and treasury’s payment-run grant simultaneously — the configuration an autonomous background agent most naturally gets.
mechanism that blocked it	A static predicate over role assignments, evaluated per principal against a ruleset of conflicting function pairs.
intervenes at	grant
configuration assumptions	The ruleset must contain the pair, and the analysis must actually be run against technical and communication users. Secondary sources suggest those principals frequently do not appear as distinct identities in access-risk tooling, which makes this an assumption worth stating rather than a given.
operational cost	None at runtime; it is an offline analysis.
generalisation boundary	Holds only where grants accumulate on one principal. X8 shows it does not see the same conflict composed across two propagated principals — so the control is correct and its scope is narrower than the harm.

evidence status	<i>found only in secondary material; no primary source read</i>
reproduce	python3 verify.py — the technical-user arm must be flagged, or the ruleset is inert and X8 proves nothing.

What the success means. The counter-intuitive result, and the one the held register exists to protect: the architecture that looks worse on every checklist — a technical user hoarding grants — is the one the modelled control can see. Principal propagation, which any reviewer would prefer, is the one it cannot. A control is only as good as the shape of the principal it was designed to read.

H4 — Content-ranging steps of the transport-governance surface (static check variant, peer review, quality-system exercise) — CONTESTED SPECIFICATION

failure definition	A transport whose released objects change system behaviour in a way nobody authorised — here, a change to an FI validation exit that stops the tolerance predicate firing for a document class, which is the control this paper’s own principal finding depends on.
strongest attack attempted	Forty harmful transports made identical at request level to forty legitimate ones: same owner, same target, same request class, same object types, same object count, same naming shape. The only difference is what an object does once it is active, which is the one thing a request-level predicate cannot read. The condition is enforced in code by <code>assert_transport_indistinguishable()</code> .
mechanism that blocked it	A predicate evaluated against the transported objects themselves — a static check catalogue matching the object’s content, a human reading the change, or a functional exercise of the affected path in the quality system before the production import.
intervenes at configuration assumptions	action Two assumptions, and the experiment refuses to hide either. The static check discriminates only if its catalogue contains a rule for this harm class, which is unverified for delivered SAP check variants and is swept as a parameter rather than assumed. Human review and quality-system exercise discriminate only in proportion to the coverage a team actually achieves, which no mechanism guarantees and which is therefore also swept.

operational cost	Not measurable from this model, and the attempt to report it as measured is loss L6. Cost here is set entirely by the rate at which a content step stops a benign transport, which is a swept parameter with no measured value: at five percent the surface still clears the 95% bar X7 was held to and at ten percent nothing does. What the contrast with X7 establishes is a difference in KIND rather than in price — an extent mismatch makes the exchange rate a property of the control-property pair that no implementation can improve, while a subject match makes it a property of the implementation.
generalisation boundary	Holds against the behavioural property. Against the narrower property that released code conforms to the change request that was approved, only the human steps retain the subject match — a pattern-matching catalogue cannot read a change request. That alternative specification is defensible and the pair is recorded as contested for exactly that reason.
evidence status	<i>found only in secondary material; no primary source read</i>
reproduce	<code>python3 -c "from sapsec.experiments import x11; r=x11(); print(r['n_discriminating'], r['request_only_discriminating'])" — 2512 and 0.</code>

What the success means. The result is close to definitional and is reported that way: a control that reads the property's own subject is not a surprising thing to find sufficient. What earns it a place is the contrast one step away. In the 800 configurations whose active steps range only over the request — release authorisation, approval — not one discriminates and all forty harmful transports reach production in every single one, at every setting of every parameter. Two decisions in the same governance surface, taken minutes apart by the same organisation, and only one of them is about the thing the property is about.

Gaps that survived

A gap may not appear here until the strongest existing mechanism a practitioner would reasonably claim closes it has been named *and* tested.

G1

gap	An aggregate outcome produced by individually-authorized actions that are per-document indistinguishable from legitimate work.
experiment	X7

strongest existing mechanism	FI tolerance groups, purchasing release strategies, organisational level, document-type authorisation group — every value-carrying and scope-carrying mechanism we could identify, swept exhaustively.
was it tested? result	yes 12,288 configurations. 10,398 hold the outcome below materiality; the best retains 37.5% of legitimate throughput and none retains 95%. The surface can throttle; it cannot discriminate.
evidence status	<i>found only in secondary material; no primary source read</i>

G2 — CONTESTED SPECIFICATION

gap	A duty conflict composed across two principals by one agent, where each principal is individually clean.
experiment	X8
strongest existing mechanism	Access Risk Analysis run per principal, and run against the technical user that would accumulate both grants.
was it tested? result	yes Both propagated principals clean; the composition completes; the technical-user variant IS flagged, which confirms the ruleset is not inert. The harm is pre-existing — two colluding humans produce it identically — so agents change the price, not the possibility.
evidence status	<i>found only in secondary material; no primary source read</i>

G3 — CONTESTED SPECIFICATION

gap	Attribution of an action to a human or to an agent, from the evidence layer alone.
experiment	X9
strongest existing mechanism	The Security Audit Log's own correlates: terminal field, session identifier, timing density, and whatever change-document metadata carries alongside the user ID.
was it tested?	yes

result	Tested in X12, which repairs loss L2. 512 conditions over concurrent actors behind one propagated principal. Retention depth changed nothing in any of the 18 condition groups where no recorded field separated the actors, and the best accuracy reached in any of them is chance. Every condition that did attribute had a field that names the origin. For the practitioner's actual objection — an agent posting hundreds of documents in minutes is obviously not a person — the upper bound on ANY procedure reading principal, transaction, terminal and timestamp equals the accuracy of naming the busiest actor for every record without reading anything, at every agent action rate tested. The density signal establishes that machine-speed activity occurred. It attributes no individual action.
evidence status	<i>not found in the reviewed control surface — this is a statement about our review, not about SAP</i>

4 controls held (1 contested), 3 gaps recorded, 0 blocked from the gap register because the strongest existing mechanism has not been tested: none.

SAP Control Surface Specification

Generated by `python3 surface.py`. The validity foundation of the paper, and currently its weakest artefact.

product	UNSPECIFIED — must be fixed before publication. The reconstruction is shaped by S/4HANA on-premise FI and GRC Access Control, but no release was chosen, and the mechanisms differ across S/4HANA Cloud, ECC and Business ByDesign.
release date	UNSPECIFIED. 31 July 2026

Nothing in this paper is yet verified against a deployed SAP mechanism. The accurate description of the work is *tested against a reconstructed SAP authorisation model*, not *tested against SAP*. The subtitle says exactly that and is computed from the release state rather than chosen, so it changes by itself when at least M2 and M4 reach SAP level.

Levels

level	meaning
FORMAL	a result about the shape of the modelled control
IMPL	a result in the reference implementation
SAP	a verified claim about a deployed SAP mechanism, primary-sourced

Mechanisms modelled

M1 — Authorization objects and AUTHORITY-CHECK (*IMPL*)

modelled as	<code>Authorization.permits()</code> ; per-instance evaluation, no union of field values across instances
fields modelled	<code>F_BKPF_BUK</code> (BUKRS, ACTVT), <code>F_BKPF_BLA</code> (BRGRU, ACTVT), <code>F_LFA1_BUK</code> (BUKRS, ACTVT), <code>F_REGU_BUK</code> (BUKRS, ACTVT), <code>S_TRANSPRT</code> (ACTVT)
primary source	No primary source read. Object names and field semantics from secondary material. Needs: the authorization object documentation for each of the five, confirming field lists and check semantics.
load-bearing assumption	That SAP evaluates per instance rather than unioning fields. A union model is strictly more permissive and would have manufactured findings, so this assumption is conservative in our favour and still needs confirming.

M2 — FI tolerance groups (IMPL)

modelled as	<code>ToleranceGroup.permits()</code> ; per-document and per-line amount ceilings
fields modelled	amount per document, amount per open-item line. Cash-discount percentage NOT modelled
primary source	No primary source read. Needs: OBA4 documentation confirming which limits are per user, per company code, and whether any limit spans documents.
load-bearing assumption	That no tolerance field retains state across documents. If one does, G1 is wrong and the gap register loses its principal claim. This is the single most damaging thing that could be found in the primary sources, which is why it is listed first among the assumptions.

M3 — GRC Access Risk Analysis (IMPL)

modelled as	<code>SodRuleset.violations()</code> ; static predicate over one principal's grant set
fields modelled	conflicting function pairs, each function a set of (object, activity)
primary source	No primary source read. Secondary material reports that the delivered rule list is not exhaustive and that implementing every delivered rule does not guarantee compliance. That reading supports the paper's framing, which is a reason to be careful with it: it is used in the specification-sensitivity audit as independent evidence for what the vendor claims, and until the primary text is read that evidence is secondary and the audit entry says so.
load-bearing assumption	That analysis is per principal and static. If ARA offers a process- or workflow-scoped mode, G2 narrows sharply.

M4 — Security Audit Log (IMPL)

modelled as	<code>SalLog</code> ; user, transaction, message, terminal
fields modelled	user ID, tcode, message, terminal, timestamp and clock granularity. Change-document metadata, table logging and read-access logging remain NOT modelled
primary source	No primary source read. Needs: the SAL field list, and the change-document schema, to establish what correlates actually exist.

load-bearing assumption	That no MODELLED field distinguishes one actor from another. X12 tested that assumption rather than resting on it — terminal, transaction code, clock granularity, session gaps and retention depth are all swept — and the assumption held: retention changed nothing where no field separated the actors. Loss L2 is repaired. What remains unmodelled is the three other evidence streams above, and a correlate in any of them would narrow G3 further.
-------------------------	---

M5 — Principal propagation (IAS to S/4HANA) (FORMAL)

modelled as	each agent session holds exactly one principal's grants; nothing persists between sessions but world state
fields modelled	the identity under which an agent-initiated action executes
primary source	No primary source read. Secondary material indicates Joule runs under the calling user and respects that user's authorisations. Needs confirmation, and needs the autonomous/background case, which may differ.
load-bearing assumption	That the propagated identity carries no marker of having been reached through an agent. If a marker exists, G3 changes entirely.

M6 — CTS transport release authorisation (S_TRANSPRT, ACTVT 43) (IMPL)

modelled as	Cts.release() and transport.run_one() step T1; a predicate over the principal's grant and the request
fields modelled	the request: owner, target system, request class. NOT the content
primary source	No primary source read. Needs: the S_TRANSPRT field list and the activities defined for it in the named release.
load-bearing assumption	That release authorisation never inspects the transported objects. This is the assumption P1 rests on and X11 confirmed against the model; if a delivered release check reads content, P1 is wrong.

M7 — Static check variant at release (ATC / Code Inspector) (FORMAL)

modelled as	transport.run_one() step T2; a content-ranging predicate whose catalogue coverage of the harm class is a SWEPT PARAMETER
fields modelled	the behaviour of a transported object, as matched against a rule catalogue
primary source	No primary source read, and this is the largest open question in X11. Needs: what the delivered check variants actually check, and whether any rule matches a change that disables a validation exit.
load-bearing assumption	That whether the catalogue carries this harm class is unknown. It is swept rather than assumed and the results are reported on both branches; 1,296 of the 2,512 discriminating configurations stop discriminating without it.

M8 — Human review and quality-system exercise before import (*FORMAL*)

modelled as	transport.run_one() steps T3 and T5; content-ranging preventive decisions whose coverage and false-positive rate are SWEPT
fields modelled	the content of the change, and the behaviour of the change when exercised
primary source	Not a product mechanism and no primary source is possible. These are organisational practices the transport system creates a place for, and modelling them as steps with parameters rather than as guarantees is the only honest option.
load-bearing assumption	That neither coverage nor false-positive rate is a property of the system. Loss L6 records what happened when the false-positive channel was left out of the model entirely.

M9 — Post-import comparison against the reviewed baseline (*FORMAL*)

modelled as	transport.run_one() step T6; content-ranging and detective
fields modelled	the transported object, after it is active in production
primary source	Not verified. Included so the experiment can distinguish ‘no content-ranging decision exists’ from ‘none of them is preventive’.
load-bearing assumption	That a detective content check does not prevent. Trivially true of the model; the point of measuring it is that 40 of 40 flagged and 40 of 40 in production is the cleanest statement of the preventive/detective distinction the paper has.

Mechanisms excluded

An exclusion must argue why it cannot trivially close a tested gap. 3 below cannot yet make that argument, and say so: E2, E6, E5.

E1 — Purchasing release strategies (puts G1 at risk) *Excluded because:* Modelled only as a per-document value threshold, not as the full release-code and release-group machinery.

Why it cannot trivially close the gap: Release strategies are evaluated per purchasing document. Whatever the code structure, the predicate’s observation boundary is one document, so by the mismatch principle it cannot range over a period-level aggregate. Modelling the machinery in full would change the fidelity and not the verdict — **unless** a release strategy can be driven by a cumulative value, which is the thing to check.

E2 — Payment program (F110) limits (puts G1 at risk) *Excluded because:* Not modelled at all.

Why it cannot trivially close the gap: **This exclusion is not yet defensible.** The payment program is the most plausible location for a genuinely cumulative limit in FI, and if one exists that binds per run or per period, it is a direct counter-example to G1. Listed here so it cannot be quietly forgotten.

E6 — Availability Control (Funds Management / Budget Control System) (puts G1 — and the repair argument that rests on it at risk) *Excluded because:* Not modelled, and **not previously known to us**. Surfaced by the reviewer’s primary-source pass, not by ours.

Why it cannot trivially close the gap: **This is the most consequential exclusion in the file and it may not survive as one.** Availability Control evaluates total consumption against a consumable budget per control object and can refuse a posting when a configured threshold is exceeded. That is aggregate state, held at the decision point, enforced preventively — which is precisely the shape G1 asserts the authorisation surface does not carry, and precisely the control X7 proposed as the repair.

It does not automatically defeat G1, because the question is whether AVC binds the FI credit-memo path, control object and product scope we model. But it destroys a framing the paper was carrying: **the cumulative control is not missing from SAP**. It exists, in another module, and is not on the path we tested. That is a better claim and a narrower one, and it must replace any sentence implying SAP lacks aggregate-state enforcement.

E3 — SAP Enterprise Threat Detection / behavioural monitoring (puts G1 at risk) *Excluded because:* Not modelled; the paper studies authorisation, not detection.

Why it cannot trivially close the gap: Detection systems hold aggregate state by construction, so they do not refute G1 — they relocate it. The paper’s claim is that the AUTHORISATION surface cannot express the constraint, and that the enterprise’s aggregate-state machinery sits in a detection layer not wired to the authorisation decision. That relocation is the argument of the gap register and must be made explicitly rather than by omission.

E4 — Firefighter / Emergency Access Management (puts G1, G2 at risk) *Excluded because:* Not modelled.

Why it cannot trivially close the gap: EAM’s control is review of a logged elevated session. Review is a detective control over a session, so it does not close G1 or G2 preventively — but it is a real mechanism a practitioner would cite, and ‘volume defeats review’ is currently an assertion in this paper rather than a measurement.

E5 — Workflow (SAP Business Workflow) approval steps (*puts G2 at risk*) *Excluded because: Not modelled.*

Why it cannot trivially close the gap: **This exclusion is weak.** Workflow is the one SAP mechanism whose observation unit is the PROCESS rather than the document or the principal, which by the mismatch principle makes it the strongest candidate to close G2. It should be modelled before G2 is published.

Part Four — The record

Pre-registration — SAP arm

Generated by `python3 prereg_sap.py`. Do not edit by hand.

An experiment belongs in this paper only if at least one PRE-DECLARED outcome removes a chapter's principal claim, transfers it to the chapter on controls that held, or reduces it to configuration guidance.

The first book's rule - *a test that cannot cost the model anything is not a test of the model* - was well formed while the model was the subject. Here a mature control environment is the subject, so a chapter surviving with a smaller claim is a real adverse outcome, and so is a claim moving into the chapter on controls that held.

experiment	the adverse outcome that was available
X7	A clean separator retaining acceptable legitimate throughput would have REDUCED THE FIRST STORY TO CONFIGURATION GUIDANCE - 'set the tolerance group properly' - and the chapter would not have been written. The realised outcome cost the principal claim its territory: from 'cannot express' to 'can bound only at a one-to-one loss of legitimate work'.
X8	Detection by the ruleset as stated would have REMOVED THE SECOND STORY's principal claim. Detection only via the technical user would have TRANSFERRED it to the held register as a control that held. Both were pre-declared; the second turned out to be half true and is now held record H3.
X9	Reconstruction from correlates would have REDUCED THE THIRD STORY TO DEPLOYMENT GUIDANCE - 'derive the actor from what you already log'. That outcome was pre-declared and then not tested, which is loss L2. X12 is the repair and has since run; the rule-3 block it caused on gap G3 is lifted.
X11	A content-ranging preventive decision found anywhere in the transport-governance surface REDUCES the standing P1 prediction TO CONFIGURATION AND PLACEMENT GUIDANCE — 'the mismatch is real at the authorisation object and is covered elsewhere in the same surface' — which is a smaller claim than the one the formalism currently carries, and removes transport from the paper's list of open mismatches. If instead the surface's only preventive decision ranges over the request, the subject mismatch survives against the full surface and the prediction is confirmed at its stated strength. Both are pre-declared.

experiment	the adverse outcome that was available
X12	Reconstruction of the deciding actor from correlates already logged would REDUCE THE THIRD STORY TO DEPLOYMENT GUIDANCE and would falsify the formalism’s subject-mismatch clause, which asserts that no amount of retained history repairs a non-injective subject map. That clause is load-bearing: it is the half of the principle that is not about extent. This is the experiment loss L2 records as pre-declared and then not run.

5 experiments are registered for this paper; 5 have run. D1 below is a pre-registered countermechanism determination, not an experiment. 1 further experiment (X10) is registered for the research programme and is deliberately NOT a blocker for this paper — see the note beside FUTURE.

One of them — X9 — is declared in advance to be incapable of failing informatively, and is registered anyway so that its status is fixed before the results make it tempting to describe it as a discovery.

Every claim below rests on an authorisation model reconstructed from secondary sources. `help.sap.com` and `community.sap.com` refused automated retrieval, so at the time these experiments were registered and run no primary vendor material had been incorporated. That remains permanently true of X7 to X9. The project’s evidence state has since advanced and is tracked in loss L3 and determination D1; the current state is **an independent retrieval route has identified primary material, and no modelled mechanism has yet been verified against it**. Where the reconstruction is wrong, the results are about the reconstruction.

X7 — The missing rate limiter

Cost: a day · Status: RUN, 31 July 2026 – matched the WEAKENING outcome, the second of the three branches. 12,288 configurations; 10,398 hold the outcome below materiality; the best of those retains 37.5% of legitimate throughput and none retains 95%. So the model CAN bound the outcome and the claim as written – ‘cannot express’ – is withdrawn. What replaces it is narrower: because the two workloads are per-document identical, any per-document predicate removes the same proportion of each, so harm can be reduced only by reducing the work at a one-to-one exchange rate. The surface can throttle; it cannot discriminate. Positive control passed (clean separation at 100% throughput when the harmful amounts lie above the legitimate band), so the null is about the arm and not the instrument.

Claim under test. An authorisation model that decides per action and holds no aggregate state cannot express a constraint on outcome. A sequence of individually-authorised actions can therefore produce a harm that no configuration of that model prevents, and this is a property of the model rather than of any particular configuration of it. (New ledger entry S1.)

outcome	means
strengthens	The exhaustive sweep finds NO configuration of the modelled authorisation surface – activity, organisational level, document type, per-document tolerance, per-line tolerance – that permits the legitimate workload while denying the harmful sequence; and a control holding cumulative state does separate them. The gap is structural and the recommendation is to add state, not to configure better.
weakens	Some configurations separate the two, but only by also denying a material fraction of the legitimate workload. The model can express the constraint, badly. The claim then becomes one about the cost of the available separation rather than about expressiveness, which is a weaker and much more ordinary finding.
eliminates	Some configuration separates them cleanly – full legitimate throughput, harmful sequence denied. The claim is simply wrong: the authorisation model already covers the case and the correct advice is ‘configure it properly’, which is the answer SAP practitioners have been giving for thirty years and would deserve to keep giving. The SAP thesis collapses and the chapter is not written.
non-discriminating	The harmful and legitimate sequences differ in any field the authorisation model ranges over – a different transaction, company code, document type, or an amount distribution that does not overlap. If they do, the sweep separates them trivially and the experiment has measured how we constructed the attack, not what the model can express. The two workloads must be drawn from the SAME amount distribution, in the same company code, with the same document type, differing ONLY in count.

Interpretation boundary. SAP being unable to express the constraint is not a claim that SAP is insecure. It is a claim about where the control has to live. Nor may a falsification of this model be reported as a falsification of SAP: the authorisation surface here is reconstructed from SECONDARY sources, because help.sap.com and community.sap.com block automated retrieval. If SAP holds an aggregate mechanism we did not model, this result is about our model and must be withdrawn, not defended. The known aggregate-ish mechanisms – FI tolerance groups, purchasing release strategies – ARE modelled precisely so this defence is not available to us later.

Instrument check. POSITIVE CONTROL. The same sweep is run against a second harmful sequence whose amounts lie ABOVE the legitimate distribution. The sweep MUST find a

separating tolerance for that arm. If it does not, the instrument is broken and the primary result is uninterpretable – not evidence for the claim. This is the check the monotonicity sweep did not have, and it is why that sweep spent an afternoon treating 128 of its own bugs as a finding.

X8 — Composed authority across propagated principals

Cost: half a day · Status: RUN, 31 July 2026 - matched the STRENGTHENING outcome, but the result that matters was not among the three. Both propagated principals pass the ruleset; the composition completes; the payment reaches the attacker account. The instrument check confirms two colluding humans produce the identical harm, so agents introduce no new harm and the contribution is about price, not possibility. The unanticipated finding: the technical user – which every checklist marks as the worse architecture because it accumulates grants – IS flagged by the ruleset, while principal propagation, the design a reviewer would prefer, is the one that renders the composition invisible. The control rewards the architecture that gives it something to look at. That inversion was not in any of the three pre-registered outcomes, which is the second time in this project a pre-registration has been bounded by its author’s imagination.

Claim under test. A segregation-of-duties ruleset that is a static predicate over role assignments cannot see a duty conflict composed across two principals by one agent, because the conflict exists in the workflow and not in either principal’s grant. (New ledger entry S2.)

outcome	means
strengthens	Each propagated principal passes the SoD ruleset individually and in every pairwise combination the ruleset examines, while the composed sequence executed by the agent completes the conflicting pair of duties and produces the harm the rule exists to prevent.
weakens	The ruleset catches it, but only because the technical user under which the agent runs accumulates both grants – i.e. it is caught as an ordinary SoD violation on a service account, which is a known finding and needs no new argument. The contribution shrinks to ‘remember to run ARA against technical users’.
eliminates	The conflict is visible to the ruleset as stated, with no change to how SoD is evaluated. S2 is wrong and the SoD material is dropped.
non-discriminating	The agent is modelled as holding both roles at once. Then the result is a restatement of ordinary SoD and says nothing about composition. Each session must hold exactly one principal’s grants and nothing must persist between them except the world state.

Interpretation boundary. Demonstrating that a static analysis misses a dynamic composition is close to a definitional result, and it must be reported as one. The contribution, if any, is not the discovery but the location: that the control which enterprises rely on most heavily for this exact class of harm is the one whose assumption agents break.

Instrument check. The composed sequence must also be shown to be harmful when executed by two HUMANS in collusion – i.e. the harm is real and pre-existing. If it is not, we have invented a harm to fit the control.

X9 – Attribution from the evidence layer alone

Cost: an hour · Status: RUN, 31 July 2026 – 0 of 520 actions attributable as logged, 520 of 520 with one added field. Exactly the arithmetic predicted, exactly as uninformative as declared. Recorded here so that the number cannot later be cited as evidence for anything.

Claim under test. An audit record keyed on principal identity cannot answer whether an action was taken by a human or by an agent, and therefore cannot support the first question of an incident response. (New ledger entry S3.)

outcome	means
strengthens	A responder reconstructing the incident from the log alone attributes 0 of N agent actions correctly; adding a single actor field takes it to N of N.
weakens	Partial reconstruction is possible from correlates – timing density, session identifiers, terminal fields – so the gap is real but narrower than stated, and the recommendation becomes ‘derive the actor’ rather than ‘record it’.
eliminates	The existing record already distinguishes them reliably. S3 is wrong.
non-discriminating	We define both the log format and the reconstruction procedure, so a 0-to-N result is arithmetic, not measurement. This experiment CANNOT produce a discovery and is not being run as one.

Interpretation boundary. This is stated in advance to be a DEFINITIONAL result and will be reported as such. Its value is entirely in the size of the repair – one field – and it may not be presented as evidence for anything else. If the write-up leans on X9 to support S1 or S2, the write-up is wrong.

Instrument check. Not applicable; nothing here can fail informatively. Included in the register for completeness and to fix its status before anyone is tempted to describe it as a finding.

X11 – The transport-governance surface (P1, respecified)

Cost: half a day · Status: RUN, 8 August 2026 – matched the WEAKENING outcome, and the third branch fired as well. Of the configurations whose active steps range only over the request, none discriminates and every harmful transport reaches production in every one of them, so the prediction held at the pair it names. But a fifth of the space does discriminate and every configuration in it has a content-ranging preventive step active, so P1 narrows to the authorisation object and transport leaves the list of open mismatches. The third branch: wherever the only content-ranging step is detective, forty of forty harmful transports are flagged and forty of forty are in production, so the paper now has to separate preventive from detective coverage. The exact counts are in the results section and are not repeated here,

*because the first version of this line repeated them and they went stale within a day. **The experiment also produced a retraction:** its first version had no channel through which a content-ranging step could stop a benign change, so it reported zero cost as a measurement. That is loss L6, and the surviving claim is about kind rather than price. Positive control passed.*

Claim under test. The standing prediction P1 says release authorisation cannot discriminate a harmful transport, because its predicate is about the request while the property is about the behaviour of what the request contains. The counterfactual audit ruled that prediction MISSPECIFIED: release authorisation never claimed behavioural safety, and a reviewer would dismiss it in one sentence. This experiment tests the respecified question instead — **does the complete modelled transport-governance surface contain a content-ranging decision capable of discriminating the defined harmful transport BEFORE release?** The claim under test is that only content-ranging preventive decisions can do it, and that their coverage of a given harm is a parameter a deployment sets rather than a property the surface guarantees.

outcome	means
strengthens	No decision anywhere in the modelled surface — preventive or detective — ranges over the behaviour of the transported object. Every gate is about the request, its owner, its target, or the identity of an approver. The subject mismatch survives against the full surface and P1 stands at the strength the formalism gives it.
weakens	The surface contains a content-ranging preventive decision that separates the harmful transport from the legitimate ones. P1 narrows to the authorisation object alone — which is where the counterfactual audit said it should always have been aimed — and transport leaves the paper’s list of open mismatches, becoming a control-placement finding of the same shape as Availability Control.
eliminates	Release authorisation ITSELF discriminates: some configuration of S_TRANSPRT separates harmful from legitimate transports without reading their content. The formalism’s subject-mismatch derivation is then wrong, and mismatch.py --check fails by construction rather than by anyone’s judgement.

outcome	means
non-discriminating	The harmful and legitimate transports differ in any request-level field — owner, target system, object type, object count, request class. If they do, a metadata rule separates them and the experiment has measured how we built the transport, not what the surface can decide. Enforced in code by <code>assert_transport_indistinguishable()</code> . A second and subtler form: if the harmful behaviour is chosen to match a rule the modelled static-check catalogue contains by construction, the weakening outcome is manufactured. Catalogue coverage must be swept as a parameter and the result reported on both branches.

Interpretation boundary. The modelled surface is a reconstruction. Whether SAP’s delivered ATC check variants contain a rule matching this harm class is NOT answered here and may not be reported as if it were. What the experiment can establish is the SHAPE of the surface — which decisions range over content, which are preventive, which are advisory — and how the outcome depends on parameters a deployment sets. Nor may a human review step be assigned a detection rate: coverage is swept across its whole range and reported as a surface, the discipline the materiality figure got in X7. A finding that ‘review catches it’ at an assumed rate would be a finding about the assumption.

Instrument check. POSITIVE CONTROL. The same surface is run against a transport whose release is attempted by a principal WITHOUT `S_TRANSPRT ACTVT 43`. Authorisation MUST refuse it, in every configuration. If it does not, the modelled surface is broken and nothing it says about content-ranging decisions is interpretable.

X12 — Attribution from correlates (the repair for loss L2)

Cost: half a day · Status: RUN, 8 August 2026 – matched the STRENGTHENING outcome. 512 conditions. Retention depth changed nothing in any of the 18 condition groups where no recorded field separated the actors, and the best accuracy reached in any of them is chance. Of the 264 conditions that did attribute at 95% or better, every one had a field naming the origin. Retention moved the result in 28 of 96 groups and in every one of those a separating field was already present, so retention improves how well an existing signal is used and does not create one. The practitioner’s objection was answered with a bound rather than a classifier: the best accuracy available to ANY procedure reading principal, transaction code, terminal and timestamp equals the do-nothing majority baseline at every agent action rate tested. Positive control passed on all 128 single-actor conditions. The procedure itself produced two rounds of artefactual results before this one; that is loss L4.

Claim under test. The formalism’s SUBJECT-MISMATCH clause, which is the half of the principle that is not about extent. G3 says the Security Audit Log’s subject — the authenticated principal — maps non-injectively onto the property’s subject, the deciding actor, and that this is a projection failure rather than a memory failure: no depth of retained history repairs it. X9 measured only whether an actor field exists, which was arithmetic. This measures whether the actor can be RECONSTRUCTED from correlates that are already recorded.

outcome	means
strengthens	Attribution accuracy is invariant to retention depth — a responder holding one record does no worse than one holding the whole period — and rises only when a field that distinguishes the actors is present. The subject/extent distinction is doing real work, and G3 becomes a measured result rather than a definitional one.
weakens	Accuracy rises materially with retention depth under some conditions and not others. The clause is then true only where the correlates do not separate, and must be restated with those conditions attached. G3 narrows to interleaved execution under a shared session identity, which is a smaller claim than the one the formalism now makes.
eliminates	Accuracy approaches certainty from retained correlates alone, with no distinguishing field added. The subject-mismatch clause is false as written, the repair is deployment guidance — derive the actor from what you already log — and the attribution material shrinks to a note. This is the outcome pre-declared for X9 and never tested, and it is the reason L2 is recorded as a loss.
non-discriminating	The actors are made distinguishable by construction — different terminals, different transaction codes, disjoint object ranges, or timestamps fine enough that no two actions collide. Correlation then succeeds trivially and the experiment has measured the construction. The baseline condition must be the one principal propagation actually produces: one technical user, one terminal, interleaved actions. Every distinguishing field is a swept parameter, never a default.

Interpretation boundary. This is a reconstruction of one evidence stream’s record shape, not a measurement of SAP’s audit capability. SAP writes several — change documents, table logging, application logs, read-access logging — and only the modelled correlates are available to the procedure. A negative result is a result about the modelled evidence surface and must be labelled so. A positive result may not be reported as ‘SAP can attribute’: it would establish that one correlation procedure over one record shape recovers the actor, which is a statement about the procedure and the schema together.

Instrument check. POSITIVE CONTROL. The same procedure is run on a single-actor session. It MUST attribute every action correctly. A procedure that cannot name the actor when there is only one candidate is broken, and the multi-actor accuracies from it would mean nothing.

D1 — the countermechanism determination

Committed before the primary sources are read. The question is path-binding, not a survey: **can F110, Availability Control, or another standard SAP mechanism preventively evaluate cumulative credited value for the exact credit-memo process, control object, product and release used in X7?**

if	then
Availability Control directly governs the tested path	G1 ceases to be a control gap and becomes a control-placement or configuration finding : the mechanism exists, binds this path, and was not switched on. The paper's principal empirical claim is withdrawn and replaced by a smaller, more actionable one. Same conclusion, with the implementation dependencies stated explicitly. The finding becomes about the cost and the prerequisites of binding it, not about absence.
Availability Control can be bound to the path through supported composition	G1 survives narrowly , as a path-specific mismatch — and SAP itself supplies the strongest evidence that the required control shape is feasible, which makes the repair recommendation far harder to dismiss than a mechanism borrowed from another industry.
Availability Control exists but cannot govern that path or that protected property	G1 is revised or eliminated as a SAP-path mismatch. The formal result about control-property pairs is untouched; the SAP instantiation of it is not.
F110 or another standard mechanism closes the tested path	

Two of the four remove the paper's surviving finding. The project would be better off if one of those were true: an organisation that can already configure this control is in a better position than one that cannot, and a paper is a worse reason to prefer an answer than that is.

The frame, and what it is not

X10 was the only experiment registered AFTER chapter 1's frame was fixed, and therefore the only prospective test of it available. It has been moved out of this paper. The consequence is stated rather than softened: **chapter 1's maturity-versus-structure frame is retrospective and is not load-bearing for this paper's contribution.** It organises the presentation; it is not offered as validated, and no artefact here may describe it as tested.

A prediction, recorded before X10 is built

X10 will match the WEAKENING outcome: bulk reversal will cover most of the attacked session, and what survives will be a narrower claim about the fraction that has crossed a payment boundary. Confidence: low. One prior observation, in a different system, about a differently shaped control.

The first book attacked one recovery edge and it lost half of itself. That is the only prior available, it rests on a single observation in a different system, and it points at the weakening outcome rather than the strengthening one. Recording it costs nothing now and costs something later, which is the point.

Claim ledger — book two

Generated by `python3 claims_sap.py`. All claims as of 8 August 2026.

Every mechanism behind S1-S4 is reconstructed from secondary sources. `help.sap.com` and `community.sap.com` refused automated retrieval, and no modelled mechanism has yet been verified against primary vendor documentation — see loss L3 for what a later manual pass found, and the control surface specification for the current evidence level of each mechanism. Claims are about the reconstruction until that changes.

	claim	source class	confidence	load-bearing
S0-Extent	Autonomous execution can compose individually permitted actions across more actions, more principals, or a longer horizon than a deployed control observes and retains.	our-argument; instantiated by X7 (actions, horizon) and X8 (principals)	conjecture — two instances, one system, and G2 is contested	yes
S0-Subject	Autonomous mediation can separate the identity or object a control names from the actor or behaviour the protected property is about, so that the map from the control's subject to the property's subject stops being injective.	our-argument; both instances now measured (X12, X11) and both still contested on their specifications	conjecture, and the weaker half: measured, and with no uncontested instance	yes
S0-Amplifier	Human throughput was an implicit rate limiter, and removing it amplifies extent mismatch on the action and horizon axes.	our-argument; the mechanism behind X7 specifically	medium — and deliberately demoted	no

	claim	source class	confidence	load-bearing
S0a	Proposition. A decision procedure whose inputs are limited to the current principal's grants and the current action's required rights cannot discriminate two executions that are identical over those inputs and differ only in an aggregate outcome.	our-argument; a statement about a decision procedure's inputs, verified by X7's sweep	high — but note it is a proposition about inputs, not a claim about SAP	yes
S0b	Aggregate-state authorisation is not an unsolved problem. Card payment authorisation has performed velocity and cumulative checks inside the authorisation decision for decades.	our-argument from general knowledge of payment systems, now second-sourced twice over by the related-work section: Brewer and Nash formalised history-dependent access for commercial systems in 1989, and UCON gave cumulative constraints a model in 2004	high, and load-bearing in the wrong direction: it constrains S0	yes

	claim	source class	confidence	load-bearing
S0c	Logical concentration under credential separation. An autonomous workflow can preserve every credential boundary an organisation has established while concentrating action SELECTION in a single decision process. Duties remain separated at the credential layer and are unified at the decision layer, which is the layer no deployed control in the reviewed surface reads.	our-argument, from X8; the paper's least measured object, and its originality is not established — the related-work section records that the workflow-authorisation literature, which is where a prior statement of this would live, was not searched systematically	conjecture — the concept is defined, the distinguishing measurement is not yet designed	yes

	claim	source class	confidence	load-bearing
S1	Proposition, with the sweep as verification. Let legitimate and harmful documents be drawn from the same distribution F, and let the control be any predicate π on a single document. The expected value admitted from a population of n documents is $n \cdot E_F[V \cdot 1_{\{\pi(D)\}}]$, so the FRACTION of value admitted, $E_F[V \cdot 1_{\{\pi\}}]/E_F[V]$, is identical for both populations and independent of n. Harm and legitimate work are therefore reduced in the same proportion: the exchange rate is one to one, exactly, in expectation. This is a consequence of exchangeability, not an empirical law of SAP or of workloads in general.	formal consequence of the constructed condition; X7's sweep verifies it (best legitimate throughput 37.5% against a materiality/session ratio of 36.1%, agreeing to within the amount grid)	high as a proposition; the empirical contribution is elsewhere	yes
S2	A segregation-of-duties ruleset evaluated as a static predicate over role assignments cannot see a conflict composed across two principals by one agent.	own testbed (X8), with a collusion control confirming the harm pre-exists agents	high, and close to definitional — reported as such	no

	claim	source class	confidence	load-bearing
S2b	Principal propagation — the architecture a reviewer would prefer, because the agent holds no standing authority of its own — is the one that renders the composition invisible. A technical user accumulating both grants IS reported.	own testbed (X8); this outcome was not among the three pre-registered ones	high, within the reconstruction	yes
S3	An audit record keyed on principal identity correctly names the authenticated principal but, under the deciding-actor property examined here, attributes no separate identity to the autonomous process that selected the action; read as naming the decider rather than the accountable principal, it assigns the selection to a named employee.	own testbed (X9) — declared definitional before it was run	certain and uninformative: this is arithmetic, not measurement	no
S4	The remediation path has the same per-document shape as the authorisation that permitted the harm, so recovery cost scales with attack volume while attack cost does not.	not yet measured — X10 is pre-registered, with an advance prediction that it will weaken	unknown; do not quote this until X10 has run	yes

Falsification criteria

S0-Extent. A composition an autonomous workflow can perform that no control's observation boundary is outrun by. Note the honest weakness: the only UNCONTESTED instance is G1 (see `counterfactual.py`).

S0-Subject. Either instance surviving its counterfactual. G3's alternative — that an audit trail's objective is the accountable principal, not the deciding actor — is defensible and unanswered; the countermechanism has now been tested and the gap survives smaller. P1 was misspecified and has been respecified against the complete transport-governance surface, run, and confirmed at the authorisation object while being made irrelevant at the surface.

S0-Amplifier. An earlier draft made this the universal explanation for every finding, which was wrong: only X7 is fundamentally about throughput. X8 arises from a principal boundary and X9 from a subject boundary, and both occur at low volume. One explanation was being made to carry several distinct mechanisms. It is now an amplifier of one axis, not the theory.

S0a. Not falsifiable as stated; it follows from the definition of the input set. The value is in what it forbids us from saying. The earlier phrasing — *permission-shaped authorisation cannot express aggregate constraints* — invited a definitional argument and, worse, let 'permission-shaped' stand in for SAP authorisation as a whole. An enterprise decision engine may consult history, workflow state or a policy information point and still produce an authorisation decision; card payment velocity checks (S0b) are exactly that. The proposition binds only procedures with the stated input set, and whether SAP's is one of those is an empirical question the surface specification has not yet answered.

S0b. This is no longer at risk of being wrong; it is at risk of having been understated. The framing that survives is not that the control must be borrowed from another industry — loss L3 retired that when Availability Control turned out to be native to SAP, and the related-work section retired what was left of it. It is that the required control shape has been available in the access-control literature for decades and is not on this posting path.

S0c. The obvious objection is that this is ordinary collusion, and it must be answered with a measurement rather than a definition. The distinguishing questions: does the composed sequence require agreement between two accountable people? How many separately accountable decision-makers does the workflow contain? Does one policy select both steps? Can an investigator attribute the composed intent to a single controller? Until at least one of those is measured, S0c is a name for something, not a finding about it. The architect's review question it yields — *are duties separated only at the credential layer, or also at the decision layer?* — is usable today and is not thereby evidence.

S1. The proposition cannot fail; what can fail is its applicability. The real empirical claims are four, and each is separately attackable: (i) the reconstructed SAP surface is transaction-local in the tested scenario; (ii) no identified SAP mechanism supplies the missing aggregate state — at risk from exclusions E2 and E5; (iii) configuration-only mitigation produces measured business denial; (iv) a cumulative control changes the failure mode from silent financial harm to visible partial outage, refusing 80 of 120 legitimate documents. Do not quote the exchange rate as a discovery. It is the arithmetic that makes (iii) inevitable once (i) holds.

S2. A static per-principal analysis that reports the composed sequence. By construction it cannot, which is why the contribution is the location of the assumption and not the bypass.

S2b. An access-risk analysis that flags the propagated case. Ours does not, and the technical-user arm confirms the ruleset is not inert.

S3. Not falsifiable as an empirical matter. Its value is the size of the repair — one field — and it may not be cited in support of S0, S1 or S2.

S4. Bulk reversal covering the attacked session cleanly at realistic detection latencies. See PREREG_SAP.md.

11 claims, 8 load-bearing, 1 of those resting on nothing measured yet.

What this paper got wrong

Generated by `python3 losses_sap.py`. Started on day one, not reconstructed at the end.

L1 — The falsification frame in chapter 1 was constructed AFTER every experiment in this paper had already produced results. (method) *What happened:* Chapter 1 argues: if autonomous agents create new security-relevant gaps, SAP is where they should disappear; if they vanish, the first paper's findings were a maturity artefact; if they remain, they are probably structural. That is a genuine falsification criterion and it is the best idea in the paper. It was also written on 31 July 2026, hours after X7, X8 and X9 had run and returned their results.

Consequence: The damage is bounded but real, and it is bounded in a specific way worth stating. Each of X7, X8 and X9 carried its OWN pre-registration, written before its own code existed, with the outcomes that would eliminate its claim — so no individual result was shaped to fit the frame, and X7's claim was in fact weakened by its own data. What was chosen after the fact is the FRAME: the decision to read three results as a test of maturity-versus-structure. That is the same defect the first book records against its monotonicity sweep, which was run and then interpreted, and whose post-hoc reframing happened to be the one the data supported. It happened again. The repair is not to rewrite the history; it is that chapter 1's claim must carry the label. The original repair was to run one experiment prospectively under the frame - X10 - and that repair was abandoned on purpose: it made validating the frame a release blocker for a paper whose contribution is not the frame. **So the frame is admitted as retrospective and non-load-bearing, chapter 1 may not claim prospective validation, and a check enforces the label.** X10 moves to the research programme. Choosing the narrower paper over the vindicated frame is the right trade and it is still a loss.

L2 — X9 never tested the strongest existing attribution mechanism, and we did not notice until a check was written that looks for exactly that. (method) *What happened:* X9's own pre-registration named the weakening outcome: partial reconstruction from correlates - timing density, session identifiers, terminal fields - would narrow the claim from 'record the actor' to 'derive the actor'. The experiment then measured only the presence of an actor field, found 0 of 520 attributable without it, and reported the arithmetic. The correlates its own pre-registration had named were never attempted.

Consequence: A practitioner's first objection is obvious once stated: an agent posting 520 documents in four minutes from one terminal is trivially distinguishable from a human, and nobody checked. They would be right. Gap G3 is therefore blocked from the gap register by rule 3, and the honest evidence status of the mechanism is `not_found` - a statement about our review - rather than `confirmed_absent`. The wider lesson is the uncomfortable one: this hole survived a full day inside an experiment that had been pre-registered, declared definitional, verified and written up. Pre-registration constrains what a result may be claimed to mean. It does not make an experiment ask the strongest available question, and nothing in the first book's method did either. Only rule 3 does.

REPAIRED on 8 August 2026 by X12, which was pre-registered before its code existed and then run. The correlates named here were tested: retention depth changed nothing where no recorded field separated the actors, and the practitioner's objection was answered with a bound over any procedure rather than with a classifier of ours. The rule-3 block on G3 is lifted and the gap survives smaller. The loss is not deleted, because what it records is that the hole existed at all — for eight days, inside an experiment that had been pre-registered, declared definitional, verified and written up.

L3 — The control-surface reconstruction missed Availability Control, and missed it because every retrieval attempt went down one path. (method) *What happened:*

help.sap.com and community.sap.com refuse automated retrieval, including for exact document URLs. The reconstruction was therefore built from secondary material, and Availability Control – which evaluates accumulated consumption against a consumable budget per control object and can refuse a posting on that basis – did not appear in it. A later manual primary-source review found it in one pass.

Consequence: The omission changed the argument, not just the citations. The paper had been carrying the sentence *SAP lacks aggregate-state control* and proposing the missing control as borrowed from card payment authorisation. Both are now retired: the control shape is native to SAP, and the open question is why it governs one control domain and not a path with the same cumulative-risk shape. That is a better argument arrived at by being wrong.

The lesson is not that automated retrieval failed, and the paper should not present it that way – automated retrieval is not the standard, and treating a blocked fetch as an excuse would be worse than the omission. The lesson is a rule, and it belongs in the replication instrument: **a control-surface review is incomplete until the strongest countermechanisms have been searched through independent retrieval routes.** A single path missed the one mechanism capable of overturning the paper’s principal finding.

L4 – The attribution procedure in X12 produced two rounds of results that were properties of the procedure rather than of the evidence, and both looked like findings. (craft) *What happened:* `reconstruct()` decides where one actor’s session ends and another’s begins by looking for a gap in the timestamps. The first rule split on any gap larger than the smallest one retained. The second split on any gap larger than the median. Both produced a clean, quotable table. Both were wrong in the same direction: where a distinguishing field had ALREADY separated the actors correctly, the rule shredded that partition into hundreds of spurious sessions, and the scoring function – which punishes over-splitting, correctly – reported attribution accuracy of 0.13 in conditions where the right answer is 1.0. Read at face value, that was a striking result: a terminal field that names the actor does not help. It was an artefact.

Consequence: It was caught because a number was implausible rather than because any check fired, which is the uncomfortable part – nothing in this repository tests a procedure against a condition whose answer is known in advance, and the positive control for X12 tests the single-actor case, which both broken rules passed. The third rule splits only where the retained gaps are actually bimodal, and the two discarded ones are documented in the function’s own docstring rather than removed from the history. The general lesson is the one the first book keeps relearning: a measurement instrument needs its own positive control at every condition it will be read at, not only at the easy one. The bound reported alongside the procedure exists for this reason – it is the one number in X12 that no procedure defect can move.

L5 – The paper was written to the point of a complete manuscript, a docx and a Zenodo deposit without citing a single prior work, and no check in the repository could see it. (method) *What happened:* Rule 3 of the boundary map refuses to publish a gap until the strongest existing COUNTERMECHANISM has been named and tested, and it has fired: it blocked G3 for eight days. Loss L3 generalised the rule to retrieval routes. Neither was ever pointed at the literature. Every consistency check in this repository compares generated text against a source inside the repository, so a claim that was internally consistent and thirty-seven years old passed all every one of them.

Consequence: The literature search, run late, cost the paper most of what it thought it had. Extent mismatch is the aggregation problem, named by Lunt in 1989. The principle is a specialisation of Schneider’s 2000 characterisation of enforceable security policies to controls whose observation boundary is narrower than the execution. The repair is history-based

access control and UCON's mutable attributes. The closure refinement is the access-control shadow of the composability literature. The agent framing has a contemporary that names aggregation inference three months earlier. What survives is the instrument, the specification-sensitivity audit, the measurements and the negative results — which is a smaller paper and a truer one.

The lesson is a rule and it belongs beside rule 3: **the strongest existing IDEA must be named and confronted before a contribution is claimed, on the same terms as the strongest existing mechanism.** The uncomfortable part is not that the paper was unoriginal in places. It is that a project built entirely out of checks against self-deception had no check that pointed outward, and that this one was found by asking what was missing rather than by anything the machinery did.

L6 — X11's headline result — that a subject-matched control stopped the harm at no cost to legitimate work — was a property of the model, and it was promoted to the paper's sharpest contrast before anyone noticed. (theory) *What happened:* The modelled content-ranging steps read the transported object's behaviour, and in the first version of `transport.py` that reading was perfect: a step stopped every harmful transport and no benign one. Legitimate throughput was therefore 100% in every one of the 3,200 settings the model then had, not merely in the discriminating ones — there was no false-positive channel anywhere in the model for it to be anything else. The results section reported this as a measurement and set it beside X7's one-to-one exchange rate, and the abstract, the finding, the boundary map, the second figure, the fourth story and the related-work section all called the pair the strongest evidence in the paper.

Consequence: It was also reported circularly: throughput was quoted over the configurations that had been SELECTED for retaining throughput, while the X7 figure it was contrasted with came from a set filtered on harm alone. Two sides of a contrast, chosen on different criteria.

The repair adds a swept false-positive rate — the share of benign transports a content step stops anyway — and reports throughput over every configuration rather than the surviving ones. At five percent the surface still clears the bar X7 was held to; at ten percent nothing does. What survives is a smaller and more defensible claim: an extent mismatch makes the exchange rate a property of the control-property pair, which no implementation can improve, while a subject match makes it a property of the implementation, which a bad one can squander.

The lesson is the one X7 already knew and X11 did not inherit: **an experiment about the COST of a control needs a channel through which the control can be wrong.** X7 has one, because its two workloads are drawn from the same distribution and `assert_indistinguishable()` enforces it. X11 had none, and nothing in the repository asked for one. This was found by a hostile reading, not by a check.

Where this paper stands

Secure Autonomous Agents in SAP Systems — A Control-Property Review Evaluated on a Reconstructed SAP FI Authorization Model

Draft 0.1, 31 July 2026.

Not a study of SAP, and not a list of SAP control gaps. A reproducible method for mapping where a mature enterprise control set remains valid under autonomous execution and where the assumptions beneath it stop holding. SAP is the first completed instance, chosen because four decades of deployed audited control is the case most likely to refute the claim.

	Chapter	State	Experiment	Evidence
1	Why SAP?	argued	—	a falsification chapter, not an overview — and a RETRO-SPECTIVE one. If the gaps vanish here the first book’s findings were a maturity artefact; if they remain they are probably structural. The frame was written after all three of its experiments had run (loss L1), the experiment that would have tested it prospectively has been moved out of this paper, and the frame is therefore not load-bearing: it organises the presentation and is not offered as validated

	Chapter	State	Experiment	Evidence
2	The control-property pair	argued	—	the formal object. Extent mismatch, subject mismatch, and compositional closure. H2 is the worked example: its property ranges over the whole workflow, the control observes one action, and the control still guarantees it — because the property is closed under the local predicate. Without that, the principle degenerates into <i>a broader property needs a broader control</i>

	Chapter	State	Experiment	Evidence
3	Story one — one control, two properties	measured	X7	the paper's spine. The same FI tolerance group against a document-local property (H1, holds, 100% throughput) and a period-aggregate one (G1, cannot discriminate, best of 12,288 configurations retains 37.5%). The only uncontested mismatch in the paper, because materiality over a reporting period is the organisation's own property and not one we authored
4	Story two — when the property is ours	measured	X8	the method refusing a result. H3 holds: per-principal analysis reports a technical user accumulating both grants. G2 exists only because we substituted a decision-layer property SAP never claimed. Published as a proposed property with an open measurement (S0c), never as a control failure

	Chapter	State	Experiment	Evidence
5	Story three — when the countermechanism was untested	measured	X9/X12	the method refusing a result twice over, and then clearing one of the two refusals by doing the work. G3 was blocked by rule 3 — the attribution correlates its own pre-registration named were never tried — and by a contested property, since accountable principal and deciding actor are both legitimate audit objectives. X12 tested the correlates and they do not recover the actor; the bound over any procedure reading the modelled record equals the do-nothing baseline. The rule-3 block lifts, the property stays contested, and the gap survives smaller

	Chapter	State	Experiment	Evidence
6	Story four — the prediction that narrowed	measured	X11	the method losing an argument to its own audit. P1 predicted that release authorisation cannot see what is released. The audit ruled the prediction unfairly specified before it was run and required it aimed at the whole transport-governance surface instead. Respecified and run: true at the authorisation object, irrelevant at the surface, and transport leaves the list of open mismatches. What it leaves behind is H4 and a distinction that cost a retraction to arrive at (loss L6): where the property outruns the control's extent the exchange rate is forced by the pair, and where the control reads the property's own subject it is set by that decision's false-positive rate instead

	Chapter	State	Experiment	Evidence
7	The method, and what it cost	partial	X7/X8/X11/X12	the boundary map, the replication protocol, and the honest accounting: one uncontested gap, two refused, one prediction respecified before running and then narrowed by its own result, and a class claim that one instance cannot support

What one instance establishes

One completed instance cannot show that immaturity is an insufficient explanation for anything, and the finding's own bounds say so: no mechanism has reached SAP evidence level, so what was observed are gaps in a reconstruction. What one instance CAN show is that those gaps are derivable from the control-property specifications before any experiment runs, rather than from a judgement about how mature the surface is. It cannot establish that other enterprise control environments share them. That is a replication question, and the method is written to be replicable precisely because this paper cannot answer it alone.

Standing conflict of interest

This paper's falsification condition is a statement about the first book, by the same author. The interest points towards finding gaps, and therefore towards under-writing the held register, which is the control on that interest, which is why it is load-bearing and why it is the chapter primary sources are mandatory for.

4 of 7 chapters measured, 1 partial, 2 argued.

Deliberately out of scope

	why
LLM theory	the results here do not depend on how the planner works, and a chapter explaining transformers would date faster than anything else in the paper
Prompt-injection surveys	well covered elsewhere, and none of the five experiments needs an injection: every harmful action is one the agent was authorised to take

	why
AI trends and market sizing	has a shelf life measured in months and is not architecture
The future of work	not a security question, and the paper has no evidence about it
Regulatory speculation	the first book already carries a chapter on designing against a standard that does not exist; repeating it here would be padding

The blocker

Nothing in this paper is yet verified against a deployed SAP mechanism. The accurate description of the work is *tested against a reconstructed SAP authorisation model*, not *tested against SAP*. The subtitle says exactly that and is computed from the release state rather than chosen, so it changes by itself when at least M2 and M4 reach SAP level.

The dependency is not spread evenly. Chapter 3 is the paper's spine, and both of its verdicts rest on **M2 — FI tolerance groups being document-local**. If a tolerance field retains state across documents, G1 is wrong and the only uncontested gap in the paper goes with it. Exclusion **E2, the F110 payment program**, is the other place a cumulative FI limit could plausibly live and has not been examined at all.

Those two are publication-blocking in a way nothing else here is. 9 of 9 modelled mechanisms remain unverified against primary sources, and `help.sap.com` refuses automated retrieval even for exact document URLs — so this pass cannot be done from inside the toolchain that produced everything else in this repository.

Part Five — What is not done

Scope, Limitations and Future Validation

Secure Autonomous Agents in SAP Systems — A Control-Property Review Evaluated on a Reconstructed SAP FI Authorization Model

A Control-Property Review Evaluated on a Reconstructed SAP FI Authorization Model

Release state at commit unknown.

product and release scope	to be fixed — validation item B1
evidence cutoff	to be frozen at the validated edition
accurate wording	<i>Evaluated on a reconstructed SAP FI authorization model</i>
build	20 checks, 22 generated artefacts

Validation still to complete

This edition (v1.0) is a complete independent study. The four items below are the external validation still to be done before a validated edition; none is a conceptual gap in the study itself.

gate	state	
Evidence blockers	3 open / 3 total	pending
Required independent reviews	0 complete / 2 required	pending
Evidence cutoff	not frozen	pending
Frozen release build	not created	pending

Validation status — v1.0. This edition is complete as an independent study. Still pending before a validated edition: evidence blockers, required independent reviews, evidence cutoff, frozen release build. None of it is a conceptual gap in the study.

Validation items — the primary-source pass

B1 — Fix the precise SAP scope (*pending*) Product, deployment model, module and release. ‘SAP’ is not a scope and neither is ‘S/4HANA’. Choose the release the reconstructed mechanisms actually represent — not the one whose documentation is easiest to reach — then rebuild or annotate every mismatch.

B2 — Verify M2 from primary documentation (*pending*) For the named release: exact configuration name, exact field semantics, enforcement point, whether each limit binds per document, per line, per clearing transaction, per run, per account or per period, and whether ANY state persists across documents. If one does, the second half of the finding is wrong.

B3 — Resolve the cumulative countermechanisms against the exact path (*pending*) Path-binding, not a survey. Can F110, Availability Control or another standard mechanism preventively evaluate cumulative credited value for the exact credit-memo process, control object, product and release used in X7? The four interpretations are pre-registered as D1 — committed before the sources are read, and two of them remove the finding.

Independent review (planned)

Neither can be performed by the toolchain that built this repository, and that is the point of both.

R1 — An SAP FI/GRC practitioner reviews the control-surface specification only. (planned) Not the prose, not the finding. The question is whether the surface is faithfully described. Showing them the conclusion first would measure their agreement with us rather than the fidelity of the model.

R2 — Inter-rater reliability — independent researchers reproduce the Control-Property Review for the decisive H1/G1 pair, in two stages: verdict reproducibility under fixed specifications (R2A) and specification-sensitivity reproducibility (R2B). (planned) If the instrument only works in the hands of the person who wrote it, it is not an instrument; if two careful readers reach different verdicts on the same case, the categories are not carving anything real. Agreement across independent raters is the first real test of the paper’s actual contribution, and it is what would falsify the method rather than a claim. Scope, stated so it cannot be overgeneralised: this covers the H1/G1 decisive pair only. A successful outcome establishes that independent reviewers reproduced the analysis for that pair and independently evaluated its specification sensitivity — not that CPR has demonstrated reliability across all seven verdict classes. A full instrument study (compositional closure via H2, a contested specification via G2 or G3, misspecification via P1, and a genuinely unsupported case) belongs to the research programme, not this release.

Statements for the paper

Artifacts. The pre-registrations, control-surface specification, experiment implementation, configuration manifest, generated results, loss register, specification-sensitivity audit, claim ledger, narrative spine and Control-Property Review instrument are released with the paper. Every reported numeric result and every narrative summary is generated from, or checked against, the same manifests that produced the experimental artefacts: the build runs 20 consistency checks and writes nothing if any of them fails.

Evidence cutoff. *Not yet frozen.* No evidence-cutoff date or fixed product-and-release scope is asserted while the gates above are open — asserting either before the primary-source pass would be a fiction. Both are frozen at release, and this line states them once they are.

Until the blockers close

may not appear	why
any title or subtitle saying <i>tested against SAP</i>	no mechanism has reached SAP evidence level
any deployment-level conclusion	the surface is a reconstruction
any claim that the tested path lacks cumulative enforcement	Availability Control is unresolved against that path
any claim that a deployed SAP control environment has failed this test	it has not been tested; a model of it has

The figures, and where each comes from

Generated by `python3 facts.py`. Do not edit by hand.

Every module here generates its prose from its own source, which stops any one artefact drifting from the code behind it. It does not stop a figure produced by one module being typed into the prose of another and going stale there. This table is what a module quotes instead; the list beneath it is what the build refuses to let one quote.

figure	value
x7_configs	12,288
x7_hold	10,398
x7_best	37.5
x11_configs	12,800
x11_disc	2,512
x11_needs_catalogue	1,296
x11_request_only	800
x11_detective_only	800
x11_no_atc	6,400
x11_no_atc_disc	608
x11_arm	40
x12_conditions	512
x12_no_signal	18
x12_no_signal_moved	0
pairs	8
contested	4
audited	8
held	4
gaps	3
experiments	5
losses	6
mechanisms	9
exclusions	6
works	19
anticipating	4

Retired

was	is	why it changed
3,200 configurations	12,800	X11 gained a swept false-positive rate (loss L6)
1,256 discriminating	2,512	same
1,256 configurations	2,512	same
200 configurations whose	800	same
952	1,296	the catalogue share was computed by subtraction rather than counterfactually, and overstated it by half
five-of-five	8	the formalism went from five pairs to eight
three experiments	5	X11 and X12 were registered and run

was	is	why it changed
Three stories	4	a fourth story was added for X11

Why publish this

For the author. Not for reviewers, not for a preface. The test is whether this page is still believed when read cold.

This paper introduces a review procedure that decides whether a control has failed against a stated property. It distinguishes seven outcomes, four of which are refusals. Five describe what was found: the control observes the property directly; the property is wider but the local predicate composes into it; the property lies outside the observation boundary and is not closed, so the control cannot discriminate; the apparent failure rests on a property the researcher substituted for the one the organisation claims; and the strongest existing countermeasure was never tested, so no verdict is owed. The other two refuse the experiment rather than the control: the test could not have come out otherwise, and there is no evidence either way.

Applied to one reconstructed control surface, it admitted one mismatch, preserved one control through compositional closure, rejected one claimed failure because the protected property had been substituted, blocked one result until the strongest existing countermeasure was tested, and refused one of its own predictions as unfairly specified before that prediction was ever run. The two blocked items were then worked rather than argued away: the countermeasure was tested and the gap survived smaller, and the refused prediction was respecified, run, confirmed exactly where it was aimed, and made irrelevant by the same experiment.

A literature search, run last, took the principle itself away. It is a specialisation of a characterisation published in 2000, its wider form was named in 1989, and its repair has had a model since 2004. What is left is the procedure and what the procedure did.

The contribution is not any mismatch it found. It is that of the claims its own author wanted to make, exactly one survived the procedure intact — and it is a measurement rather than an idea. One was rejected outright. One was narrowed until it was about a proposed property rather than a control. One was blocked, worked, and returned smaller. One was refused before it was ever run, respecified, run, and made irrelevant by its own result. And one was retracted after the fact, because the model it rested on could not have produced any other answer.

Version 1.0. This edition is released as a complete independent study; the closing signature is held until the external validation set out earlier — evidence blockers, required independent reviews, evidence cutoff, frozen release build — is finished.

A reason to publish written before that validation is in is a wish. The page is drafted now so it is not composed under the pressure of wanting to be finished — the author signs it once the validation completes, and nothing in this repository can sign it on their behalf.

Generated at commit `unknown`.